

TRIỂN KHAI BẢO MẬT VÀ GIÁM SÁT AN NINH CHO CÔNG TY SHANGRI-LA

Tài liệu Thiết kế - Học kỳ IV

Giáo viên hướng dẫn: Nguyễn Phát Tài

Lớp: FJK.J1.2409.E0

Tên nhóm: Nhóm 8

Tên thành viên nhóm

	Tên đầy đủ	Mã số sinh viên
1.	Quách Thành Tân	JK-ENR-HA-11618
2.	Nguyễn Việt Linh	JK-ENR-HA-11617
3.	Trần Quốc Huy	JK-ENR-HA-11617

MỤC LỤC

CHƯƠNG 1: KHÁI QUÁT VỀ DOANH NGHIỆP	7
1.0 Sơ đồ Logical.....	7
1.1 Sơ đồ Physical.	7
1.2 Quy hoạch phân bố IP.	8
1.3 Hệ thống Website Công ty Shangri-La.....	8
1.3.1 Sơ đồ hệ thống Hybrid Cloud Shangri-la.....	8
1.3.2 Sơ đồ vận hành Website Shangri-la	8
1.3.3 Các tính năng của Website.....	9
CHƯƠNG 2: HIỆN TRẠNG DOANH NGHIỆP	11
2.0 Hệ thống đang vận hành và mối lo của doanh nghiệp	11
2.0.1 Hệ thống đang vận hành.....	11
2.0.2 Mối lo của doanh nghiệp	11
2.1 Hạng mục kiểm thử hệ thống.....	12
2.2 Công cụ sử dụng mô phỏng tấn công.....	13
2.3 Yêu cầu doanh nghiệp	13
2.3.1 Ngăn chặn tấn công dò mật khẩu tài khoản quản trị.....	14
2.3.2 Thu thập và phân tích dấu vết kỹ thuật số.	14
2.3.3 Phòng tránh quét port trái phép.	14
2.3.4 Bảo vệ hệ thống Cloud trước khai thác lỗ hổng SSRF.	14
2.3.5 Phòng chống tấn công SQL Injection vào website.	14
2.3.6 Phát hiện tấn công bằng hệ thống giám sát tập trung.....	14
2.3.7 Bảo vệ Database trước tấn công trích xuất dữ liệu tự động.....	14
2.3.8 Ngăn chặn nghe lén dữ liệu mạng nội bộ.....	14
2.3.9 Phản ứng tức thời với Honeypot và nền tảng SOAR.....	14
2.3.10 Bảo vệ hệ thống xác thực AD trước tấn công Kerberoasting.	14
2.3.11 Ngăn chặn chiếm quyền điều khiển và Reverse Shell.	14
2.3.12 Bảo vệ Website khỏi tình trạng làm treo hệ thống.....	14
2.3.13 Ngăn chặn lừa đảo chiếm đoạt tài khoản qua Email.....	15
2.3.14 Ứng dụng A.I Agent vào tự động hóa phòng thủ hệ thống.	15
2.3.15 Chiến lược dự phòng và phục hồi dữ liệu.....	15
2.4 Tóm tắt Giải pháp triển khai.....	15
CHƯƠNG 3: KỊCH BẢN KIỂM THỬ	16
3.1 Kiểm thử Brute-Force vào tài khoản quản trị hệ thống Active Directory	16
3.2 Ứng dụng A.I trong quá trình Footprinting và Port Scanning.....	17
3.3 Tấn công Nghe lén dữ liệu (Man-In-The-Middle / ARP Spoofing)	18
3.4 Kiểm thử Broken Access Control và triển khai xác thực API.	19
3.5 Bảo vệ Active Directory trước các kỹ thuật khai thác định danh	20

3.6 Khai thác SSRF để lấy thông tin hệ thống trên Azure.....	21
3.7 Ngăn chặn Reverse Shell và leo thang đặc quyền vào máy trạm.....	22
3.8 Bảo vệ hệ thống trước chiến dịch tấn công lừa đảo qua Email.....	23
3.9 Giới hạn tốc độ truy cập và thời lượng kết nối đến trang Web	24
3.10 Dùng WAF tự động chặn các cú pháp tấn công nhằm vào địa chỉ Web	25
3.11 Tự động hóa phân tích và Phản ứng sự cố bảo mật với Intelligent SOC.....	26
3.12 Tích hợp Wireguard VPN và Giám sát DNS Sinkhole để Quản lý truy cập	27
3.13 Tích hợp Intelligent SOC trên Azure và Phân tích sự cố qua OpenAI.....	28
3.14 Tạo bẫy Honeypot tích hợp Netmiko tự động khoá Port tấn công.....	29
3.15 Ứng dụng A.I Agent trong tự động hóa phòng thủ hệ thống.....	30
3.16 Phục hồi sau sự cố & Tích hợp cơ chế Zero Trust cùng Llama 3 A.I	31
CHƯƠNG 4: ĐỀ XUẤT GIẢI PHÁP	32
4.1 Xác thực đa yếu tố & Khóa tài khoản (Brute-force AD).....	32
4.2 Firewall & WAF bảo vệ Cloud (Footprinting/Scanning/SSRF)	32
4.3 Phòng chống SQL Injection & Sqlmap	32
4.4 Giám sát tập trung & Cảnh báo (Splunk).....	32
4.5 Ngăn chặn nghe lén (MITM).....	32
4.6 Kiểm soát kết nối & Toàn vẹn dữ liệu (Reverse Shell/Data Integrity)	33
4.0 Bảo vệ tài khoản dịch vụ (Kerberoasting).....	33
4.1 Giới hạn tốc độ truy cập (DDoS Slowloris)	33
4.2 Email Security & Least Privilege	33
4.3 Phục hồi dữ liệu sạch (Recovery)	33
CHƯƠNG 5: ĐIỀU TRA SỐ	34
5.0 Quy trình và Nguyên tắc Điều tra số.....	34
5.1 Bộ công cụ Điều tra chuyên dụng (Forensic Toolset).....	34
5.2 Thực thi Điều tra số theo Kịch bản tấn công (Forensic Scenarios)	35
5.2.1 Web & Database Forensics (Ứng dụng Node.js/React & MariaDB)	35
5.2.2 Identity & OS Forensics (Máy chủ Domain Controller - Windows Server 2022).....	35
5.2.3 Cloud Forensics (Microsoft Azure & Hybrid Cloud)	35
5.2.4 Network & Mail Forensics (Mạng nội bộ và Email lừa đảo)	36
CHƯƠNG 6: ĐÁNH GIÁ ĐỀ TÀI	36
6.0 Hiệu quả kỹ thuật theo từng phân vùng	36
6.1 Năng lực giám sát và Phản ứng sự cố (SOC)	36
6.2 Bảo toàn dữ liệu và Phục hồi sau sự cố	37
6.3 Đánh giá tổng quát	37
6.3.1 Tổng quan	37
6.3.2 Kết quả đạt được	37
6.3.3 Kiến thức và Kỹ năng tiếp thu	37
6.3.4 Ưu điểm	37
6.3.5 Nhược điểm.....	38

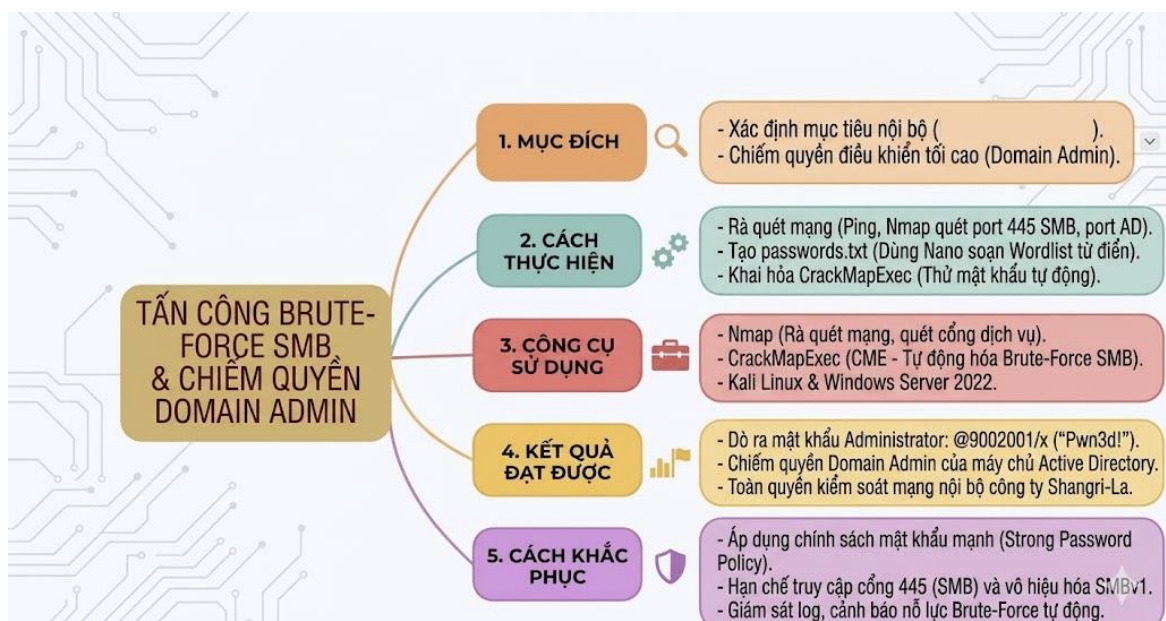
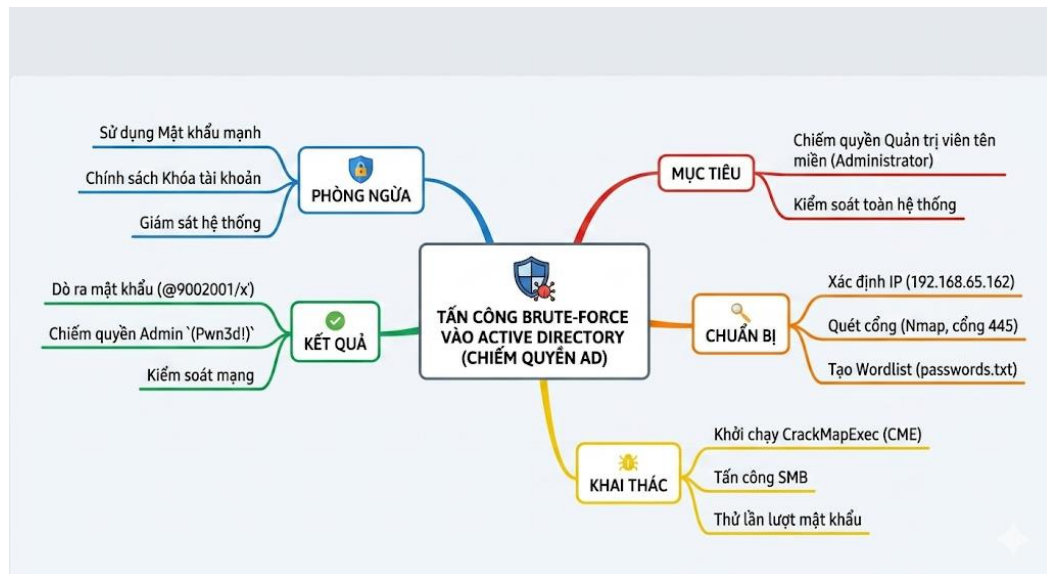
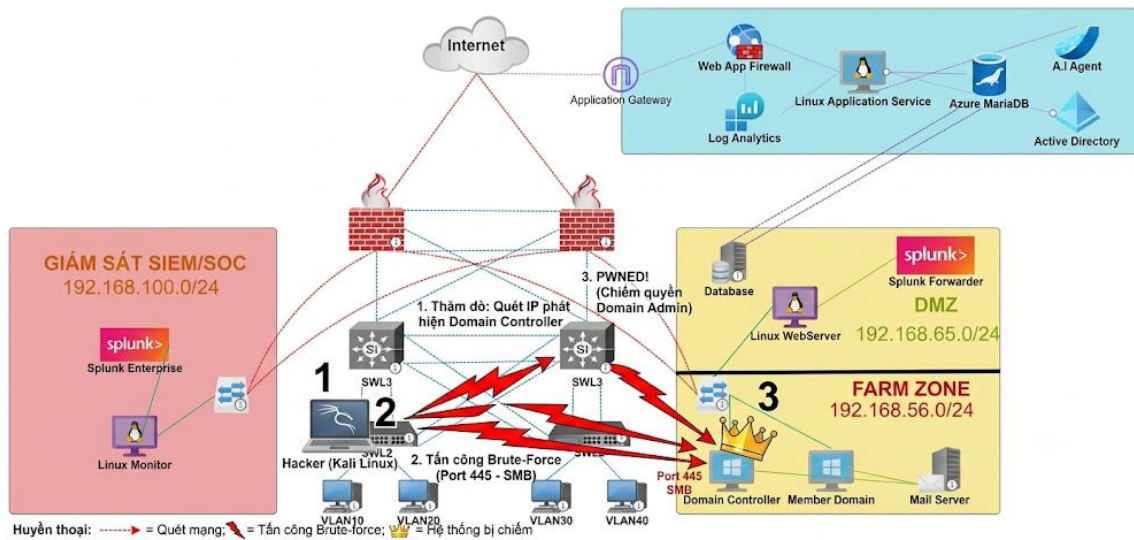
CHƯƠNG 7: ĐỊNH HƯỚNG PHÁT TRIỂN	38
7.1. Nâng cấp Hệ thống Giám sát và Phản ứng (Từ SIEM lên SOAR & XDR)	38
7.2. Hiện thực hóa Kiến trúc An ninh Không tin cậy (Zero Trust Architecture).....	38
7.3. Tích hợp Bảo mật vào Vòng đời Phát triển Phần mềm (DevSecOps).....	38
7.4. Ứng dụng Trí tuệ Nhân tạo và Học máy cho Blue Team.....	39
7.5. Kế hoạch Phục hồi sau Thảm họa (Disaster Recovery & Business Continuity)	39

CHƯƠNG 3: KỊCH BẢN KIỂM THỬ

3.1 Kiểm thử Brute-Force vào tài khoản quản trị hệ thống Active Directory

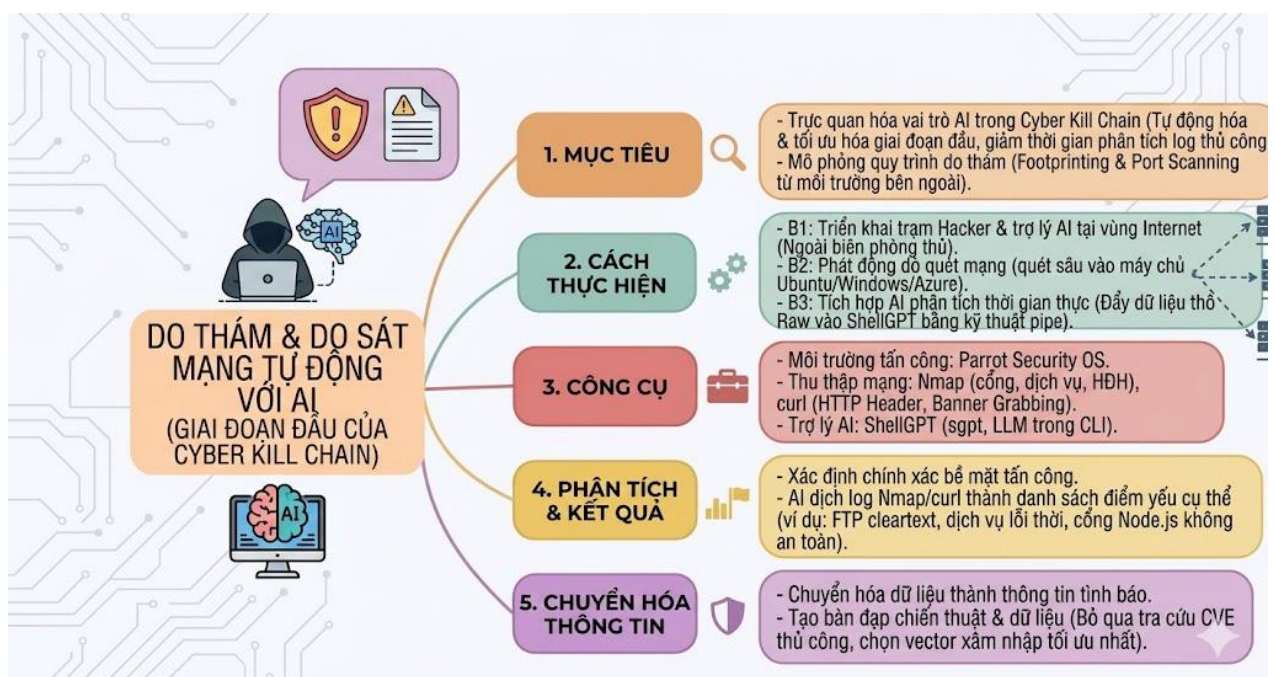
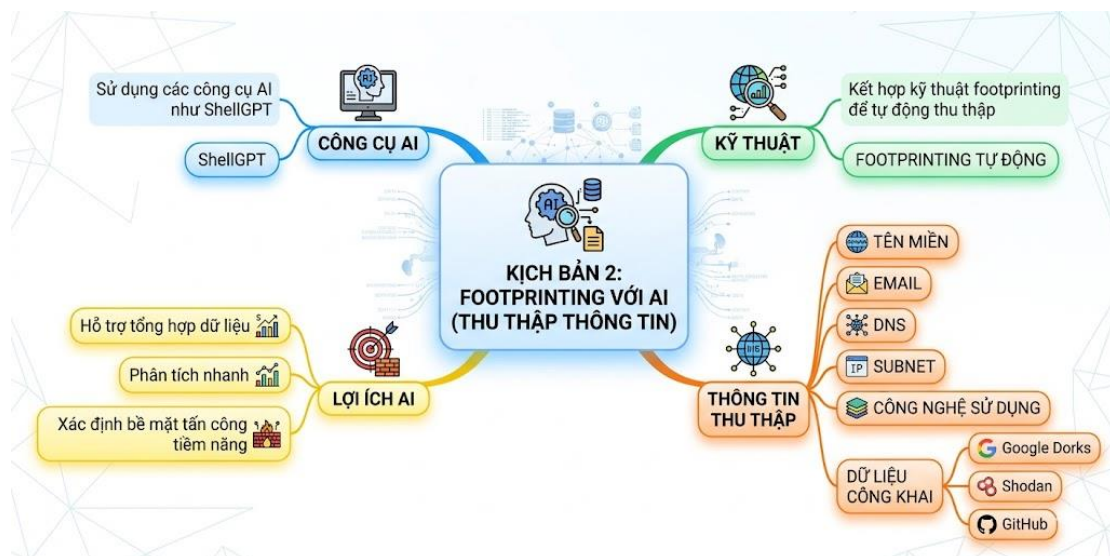
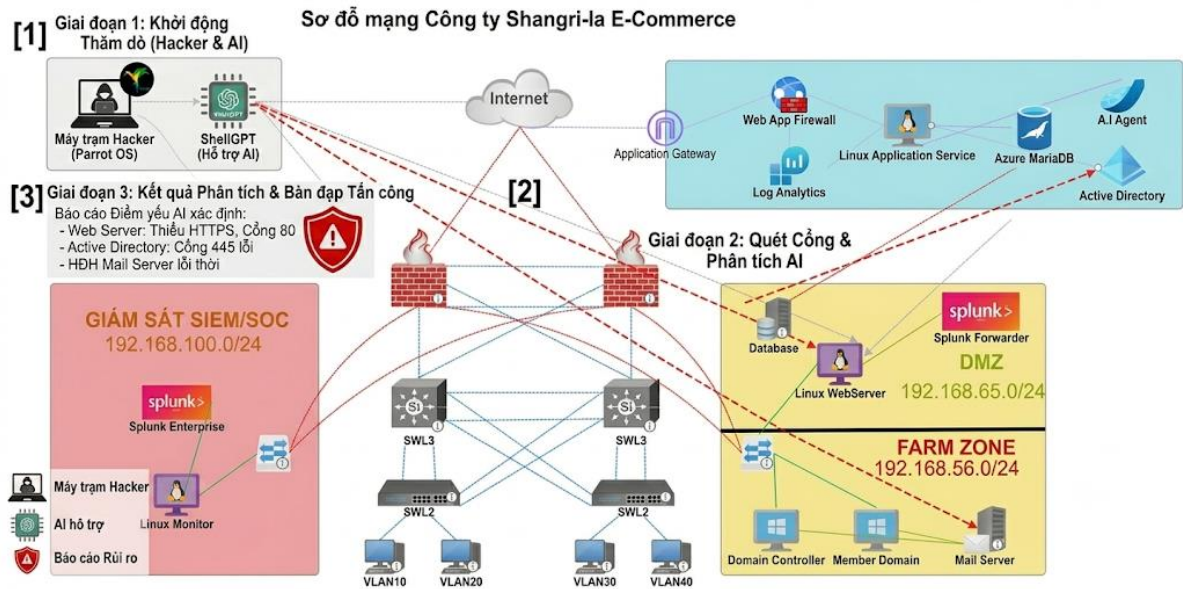
Brute-Force testing of the Active Directory Administrator Account

Sơ đồ mạng Công ty Shangri-la E-Commerce



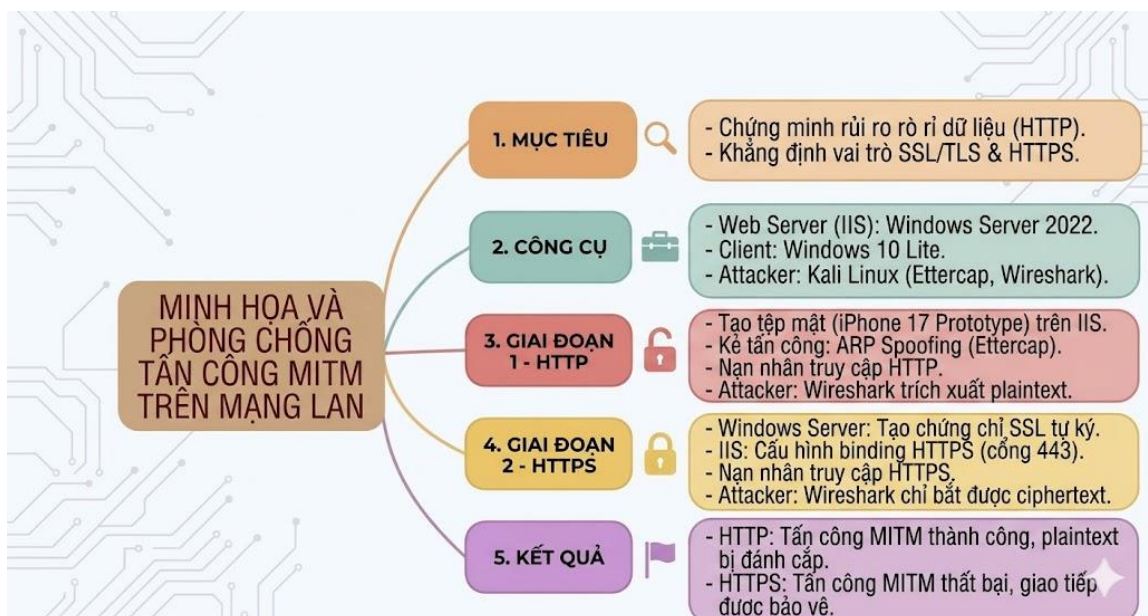
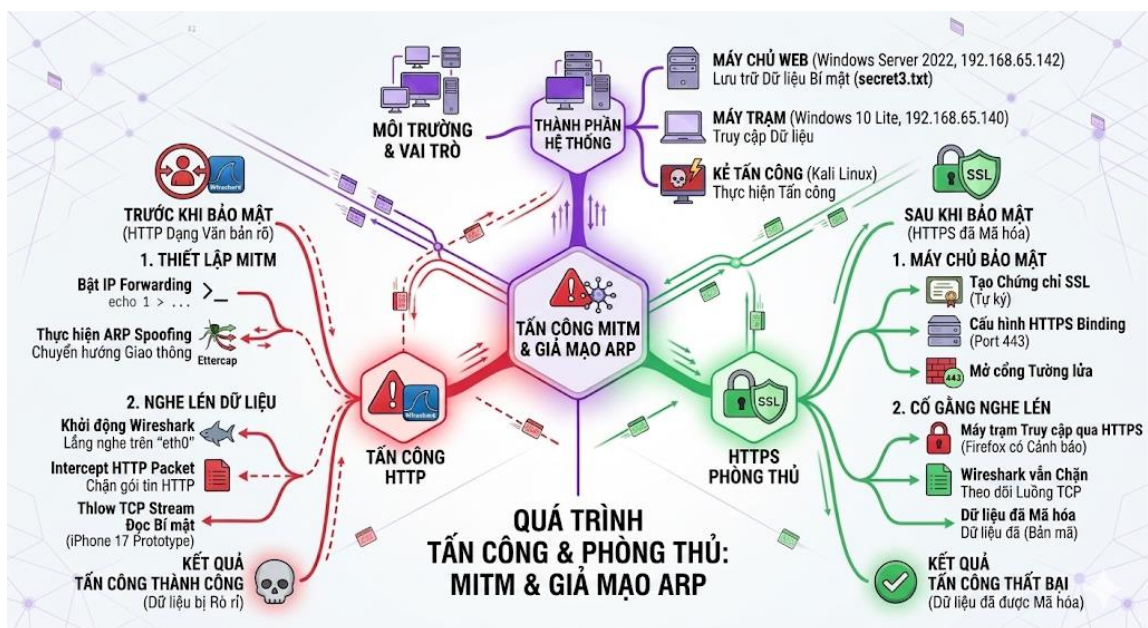
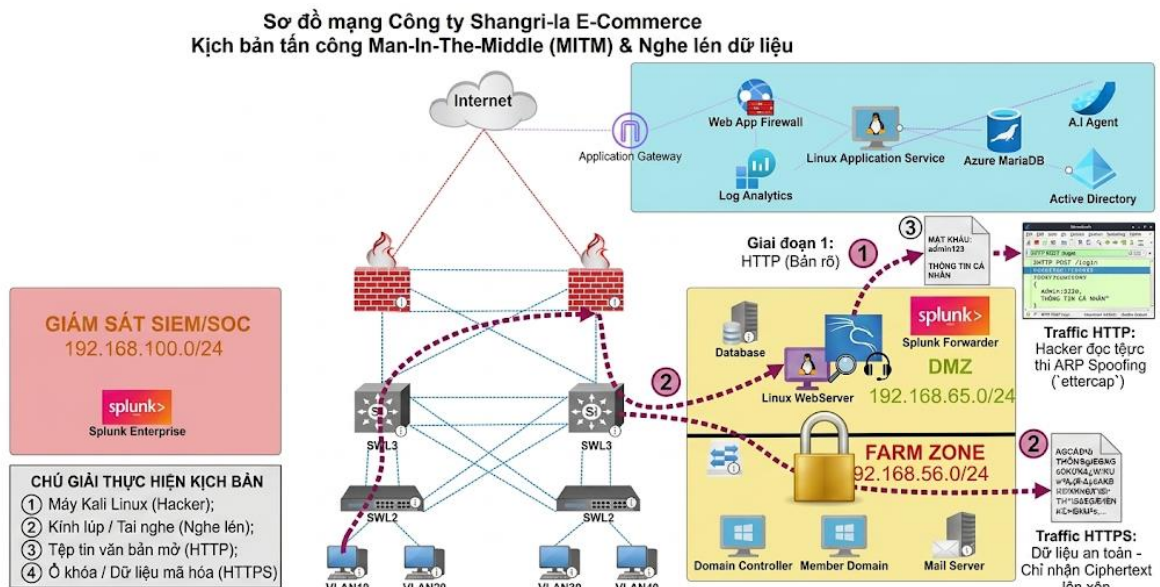
3.2 Ứng dụng A.I trong quá trình Footprinting và Port Scanning

Application of using AI in Footprinting and Port Scanning



3.3 Tấn công Nghe lén dữ liệu (Man-In-The-Middle / ARP Spoofing)

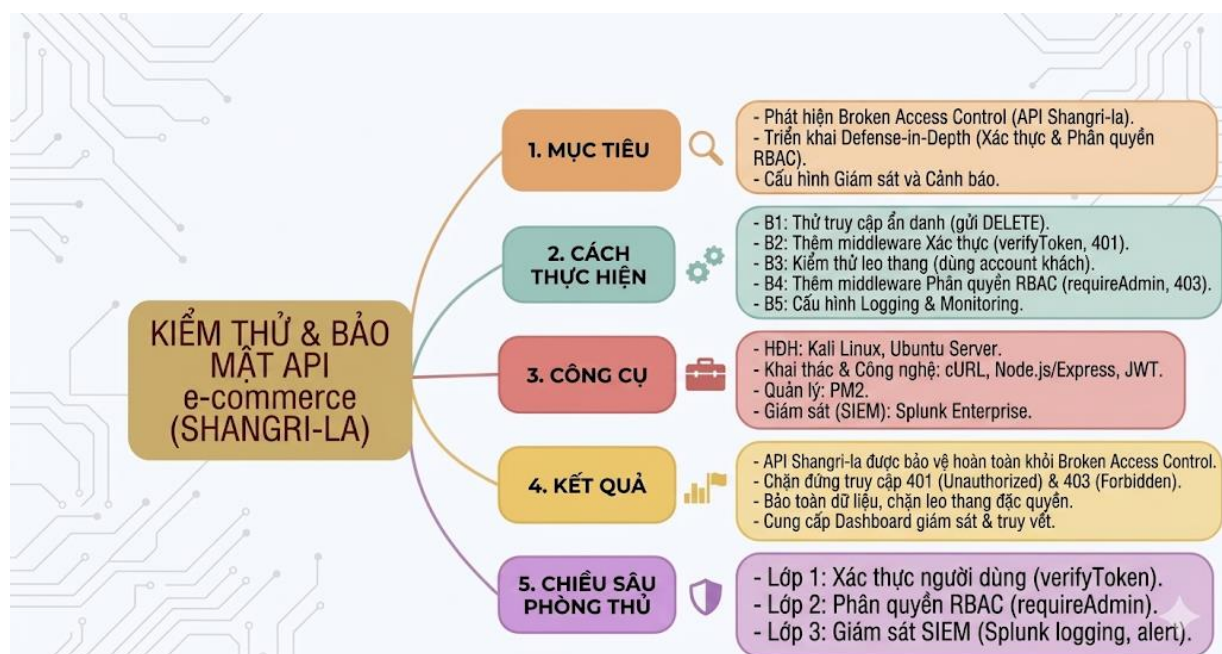
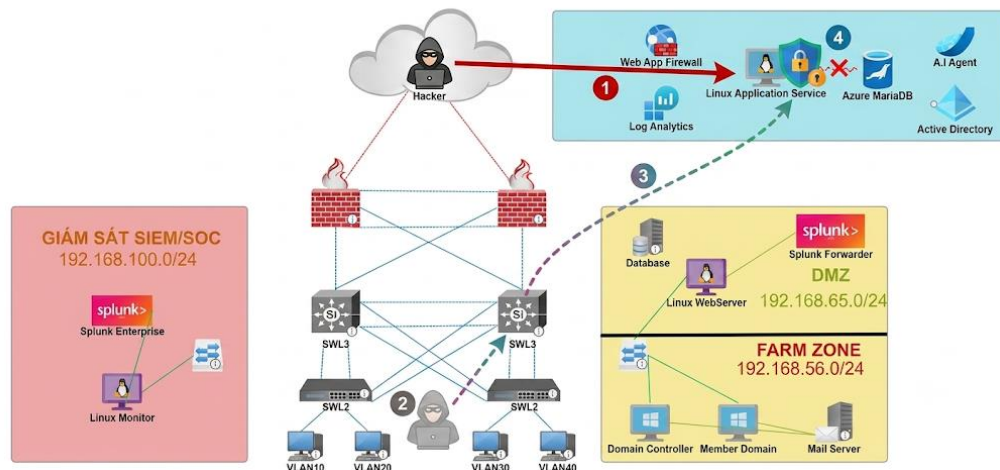
Nghe lén dữ liệu trong mạng nội bộ (MITM)



3.4 Kiểm thử Broken Access Control và triển khai xác thực API.

Testing Broken Access Control and Implementing API Authentication.

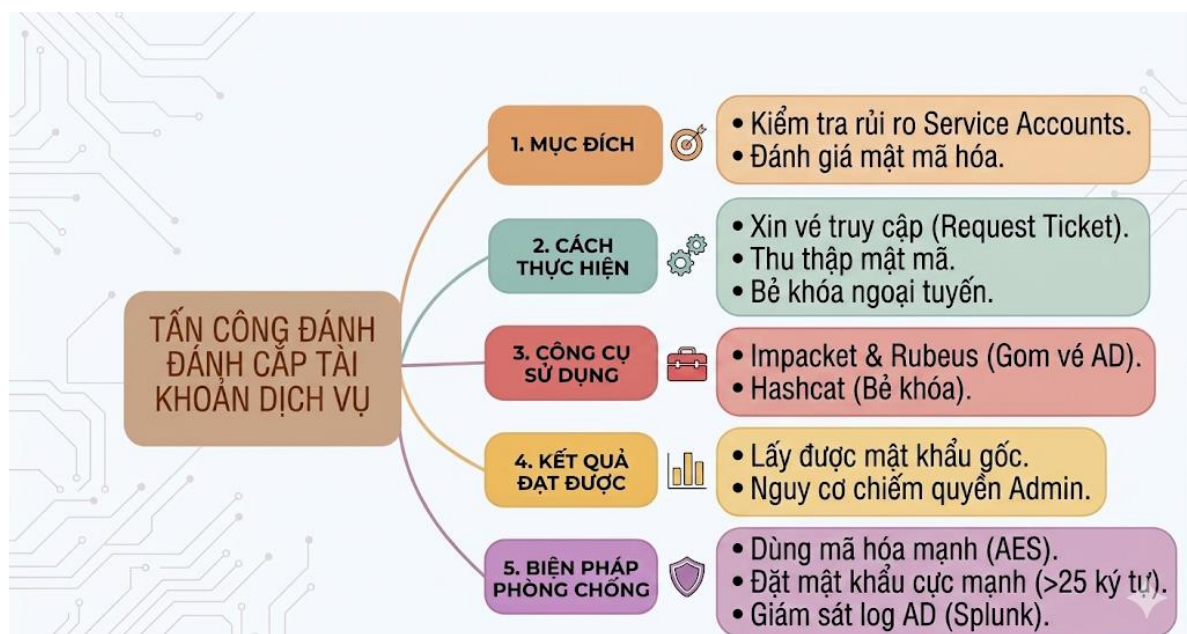
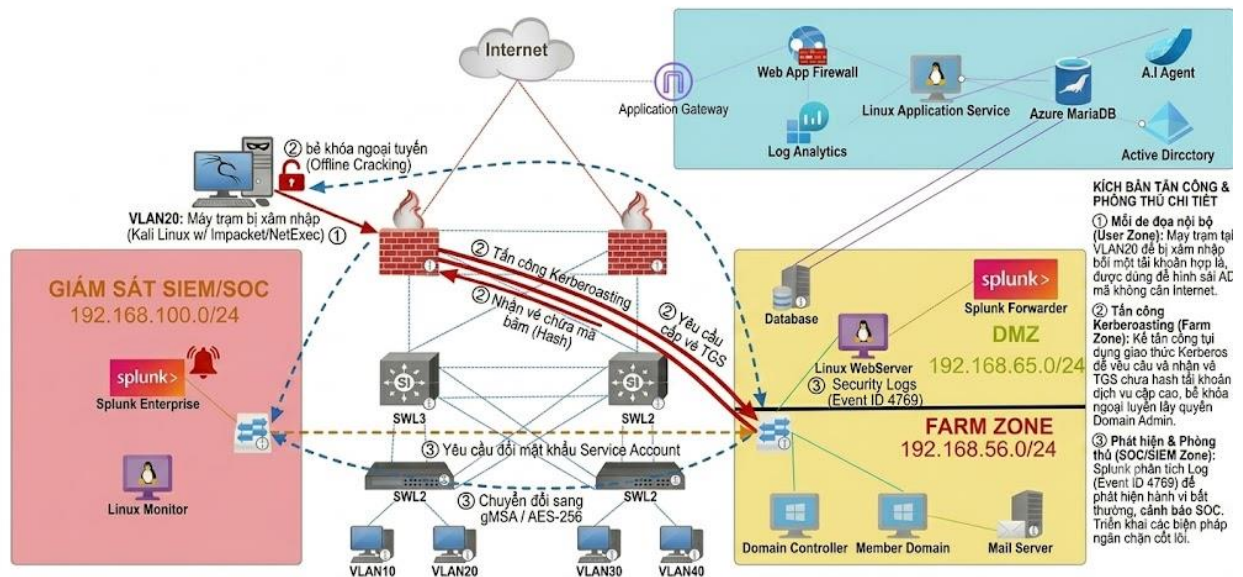
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.5 Bảo vệ Active Directory trước các kỹ thuật khai thác định danh

Active Directory Kerberos Attacks & Exploit Authentication Flaws

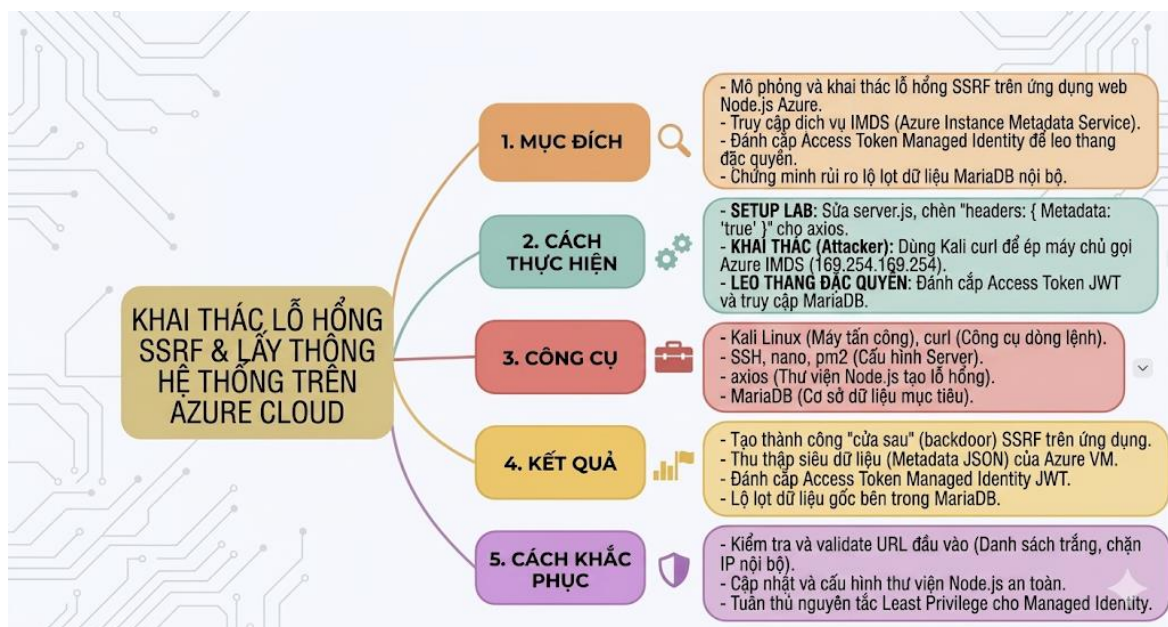
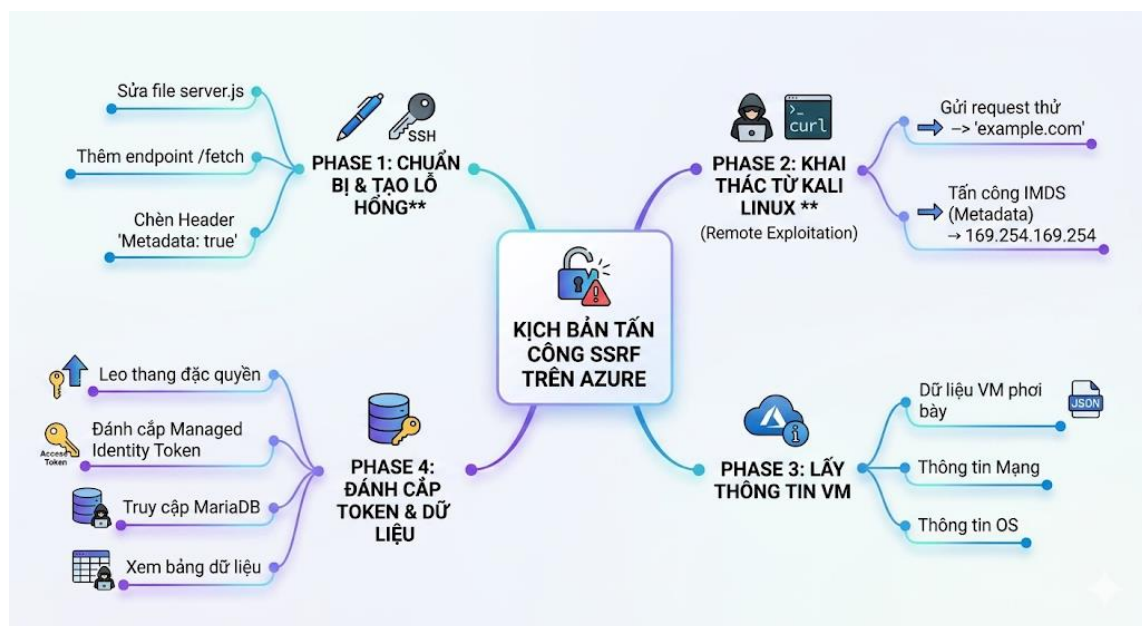
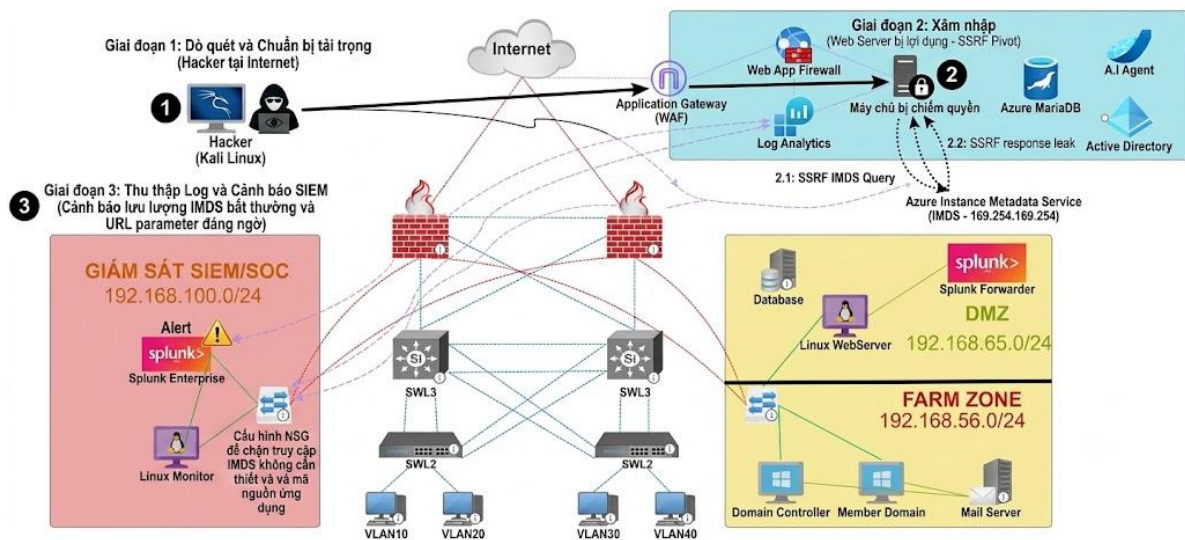
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.6 Khai thác SSRF để lấy thông tin hệ thống trên Azure

Exploiting SSRF to retrieve information systems on Azure

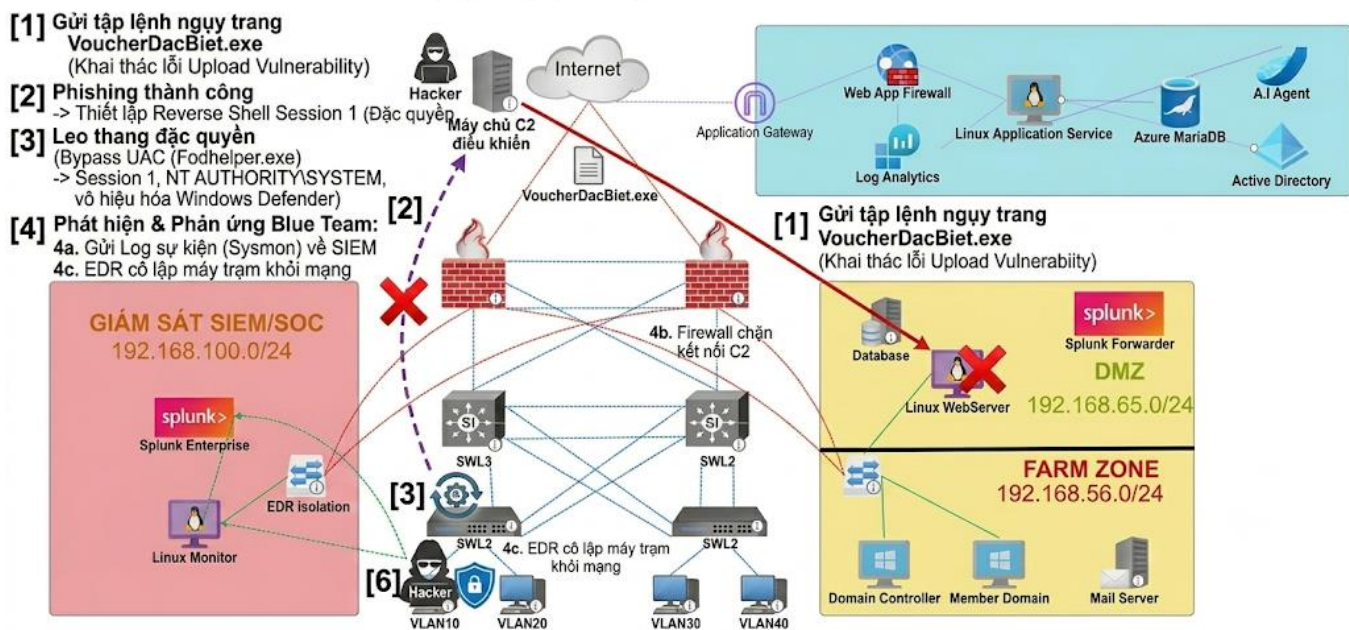
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.7 Ngăn chặn Reverse Shell và leo thang đặc quyền vào máy trạm.

Web Exploitation to Full System Control

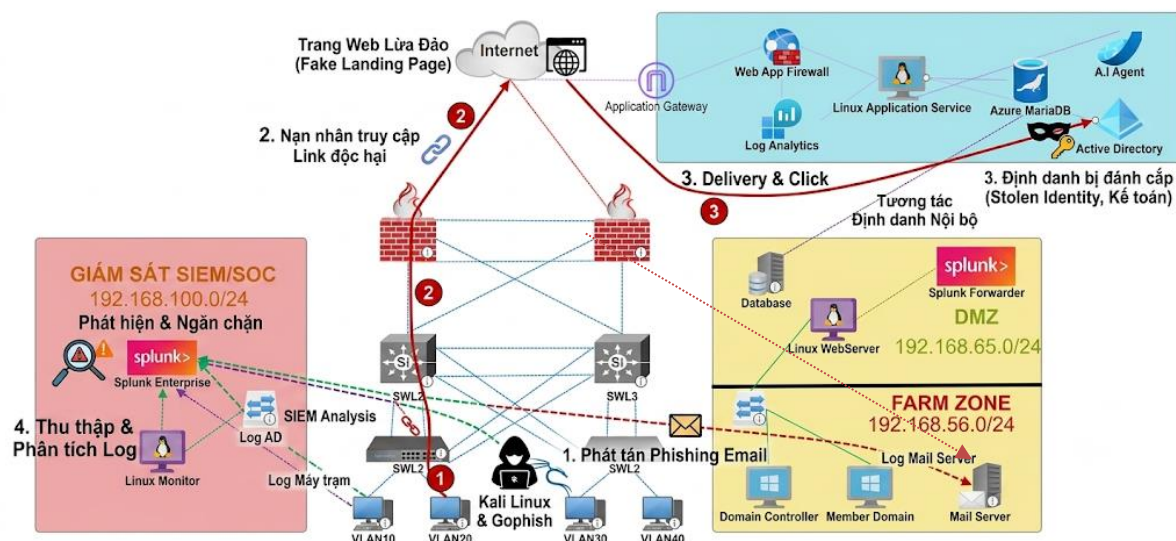
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.8 Bảo vệ hệ thống trước chiến dịch tấn công lừa đảo qua Email

Email Phishing Stimulation & Credential Harvesting

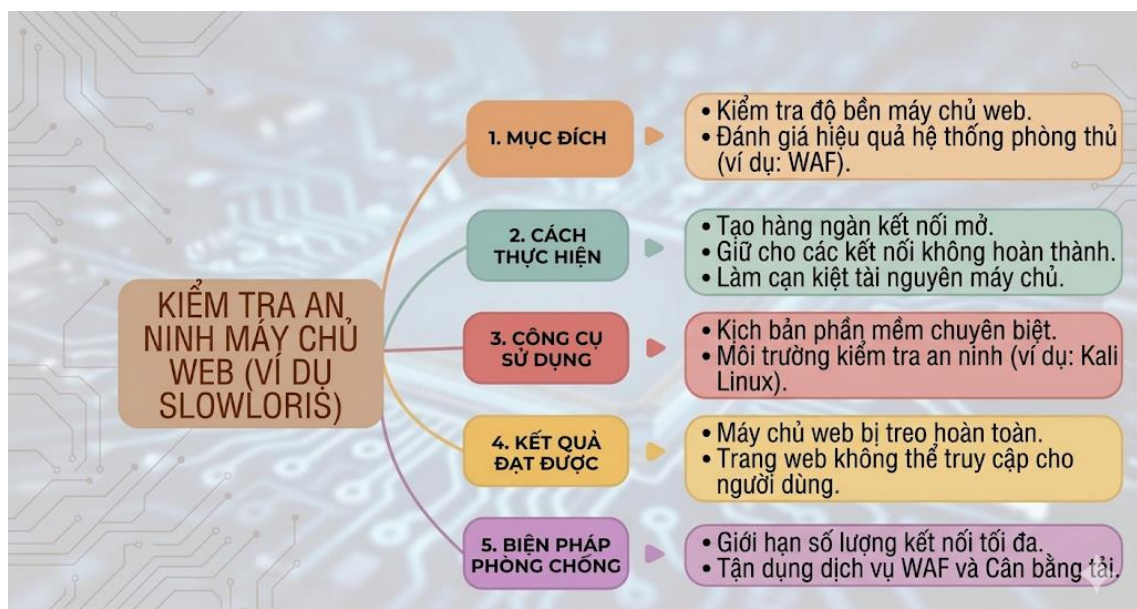
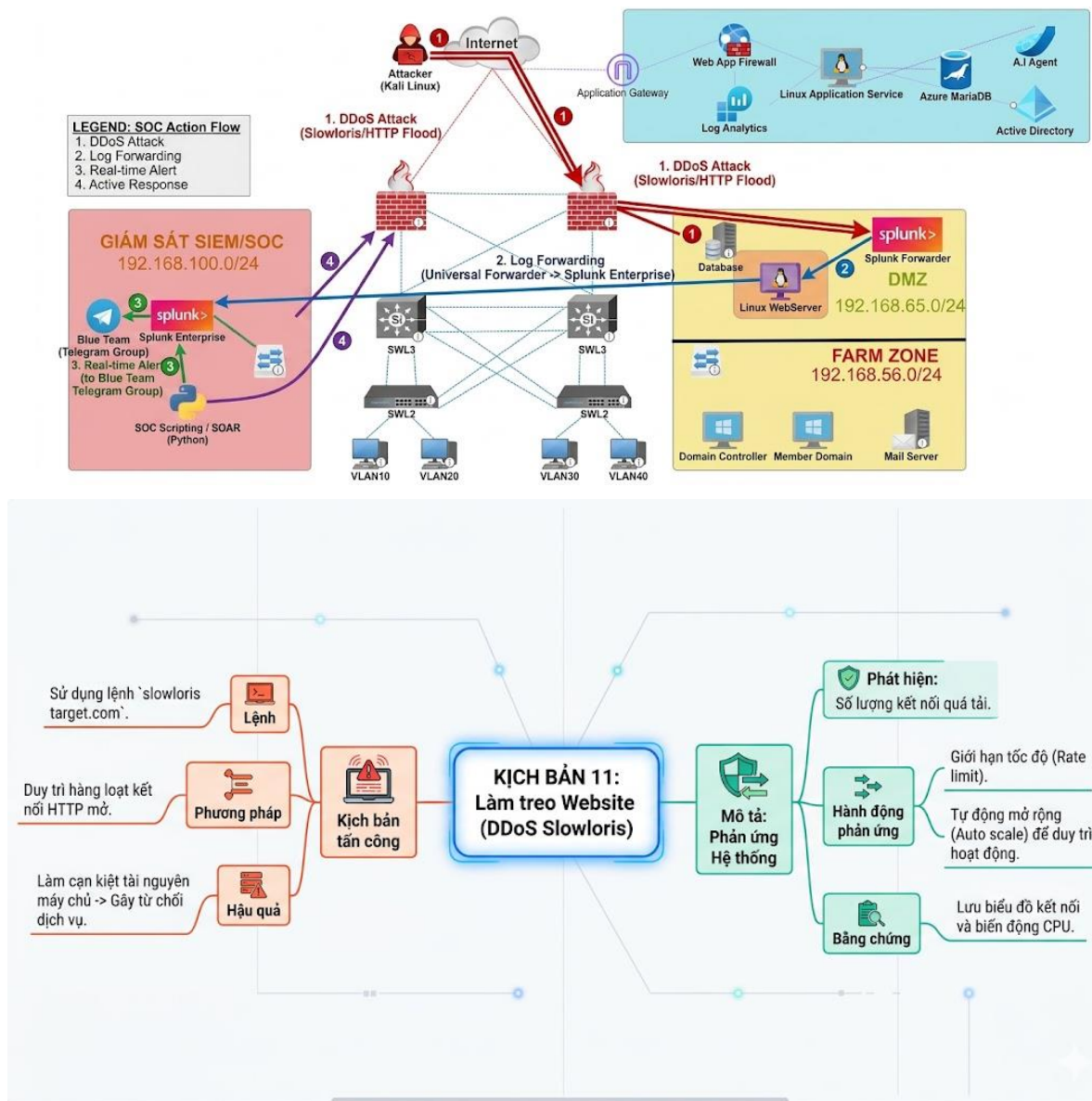
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.9 Giới hạn tốc độ truy cập và thời lượng kết nối đến trang Web

Database Exhaustion Attack & Stress Test Registration

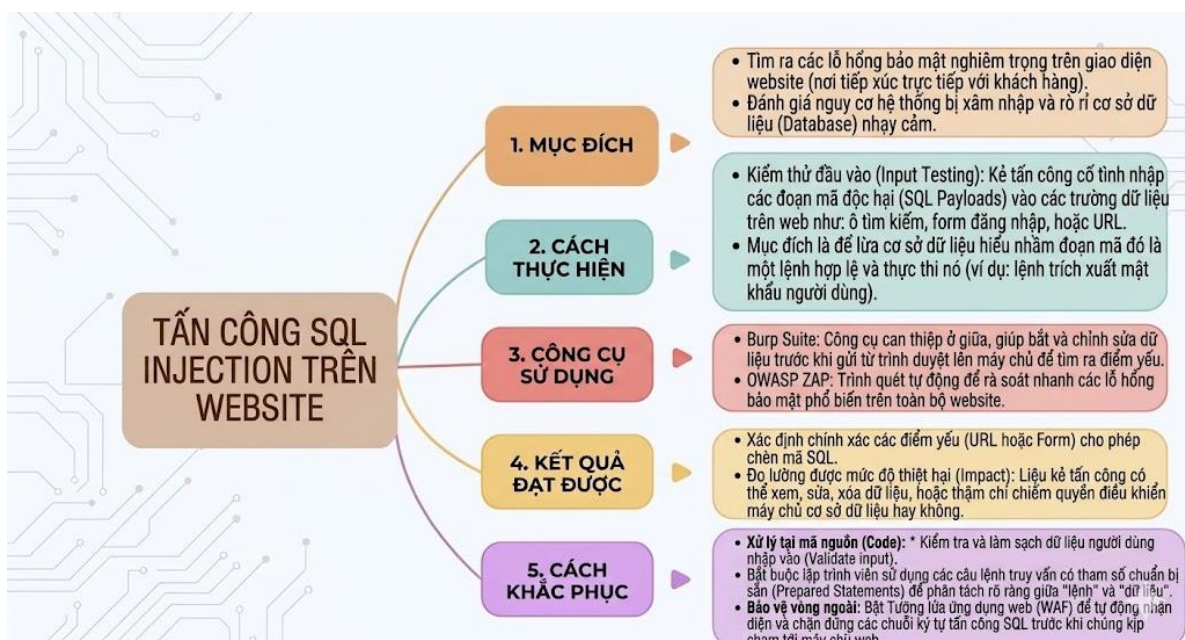
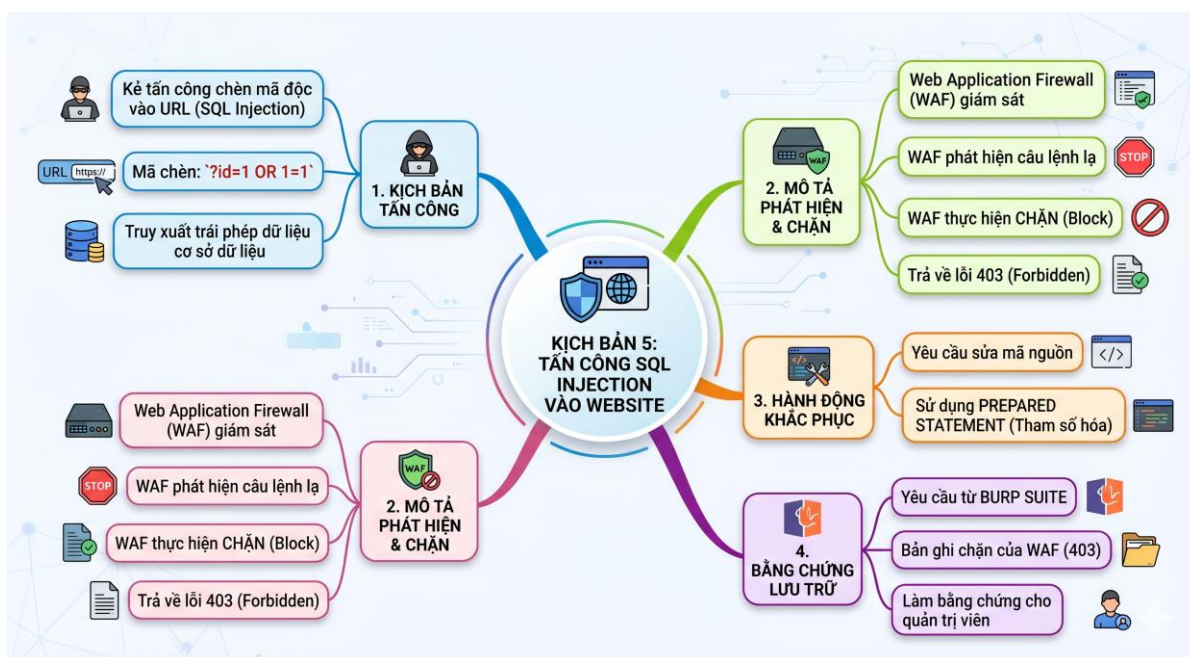
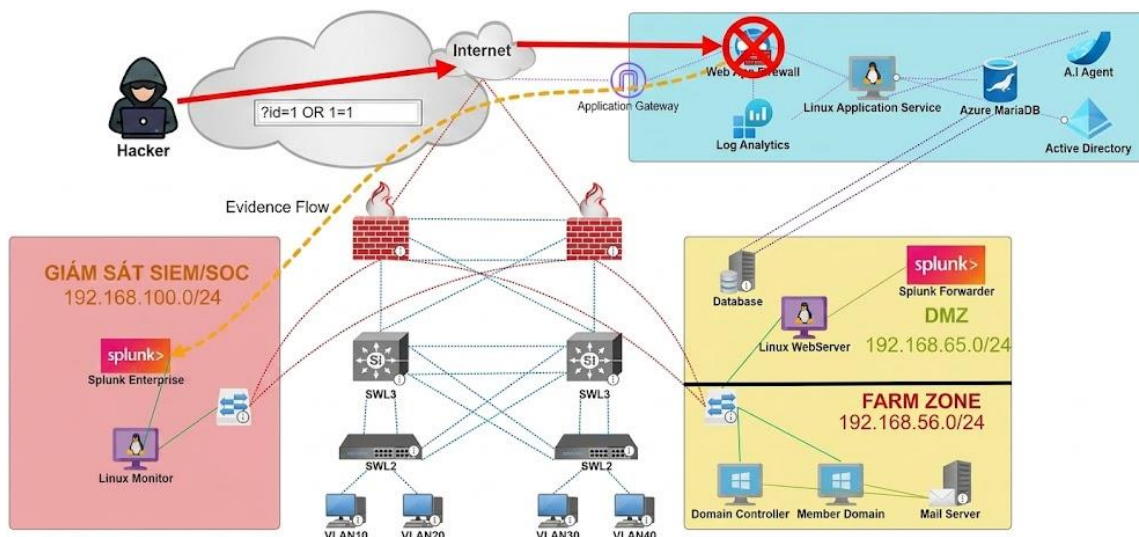
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.10 Dừng WAF tự động chặn các cú pháp tấn công nhằm vào địa chỉ Web

Tấn công SQL Injection vào website

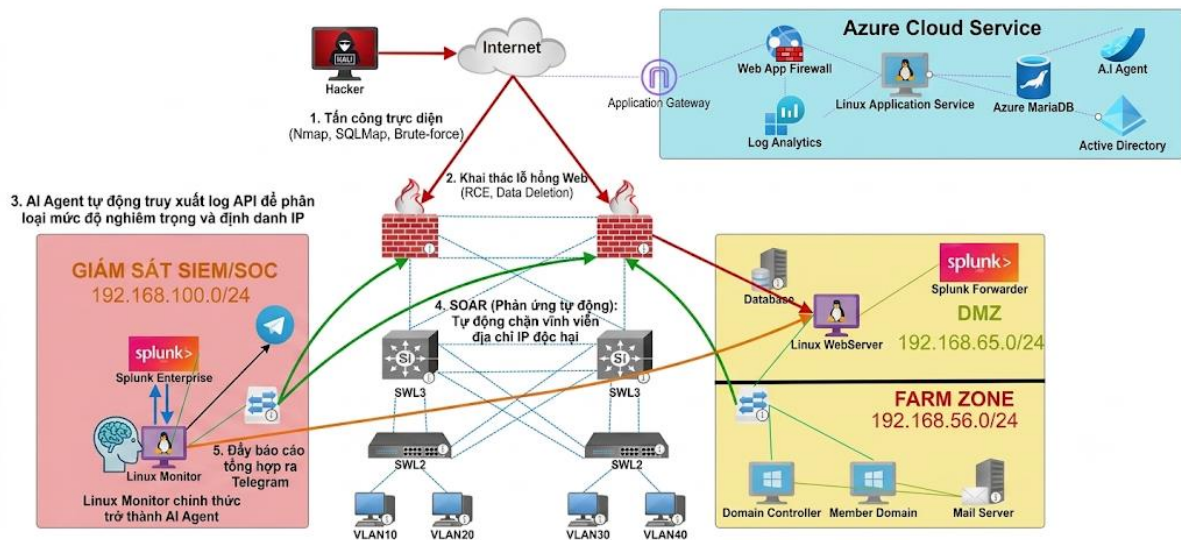
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.11 Tự động hóa phân tích và Phản ứng sự cố bảo mật với Intelligent SOC

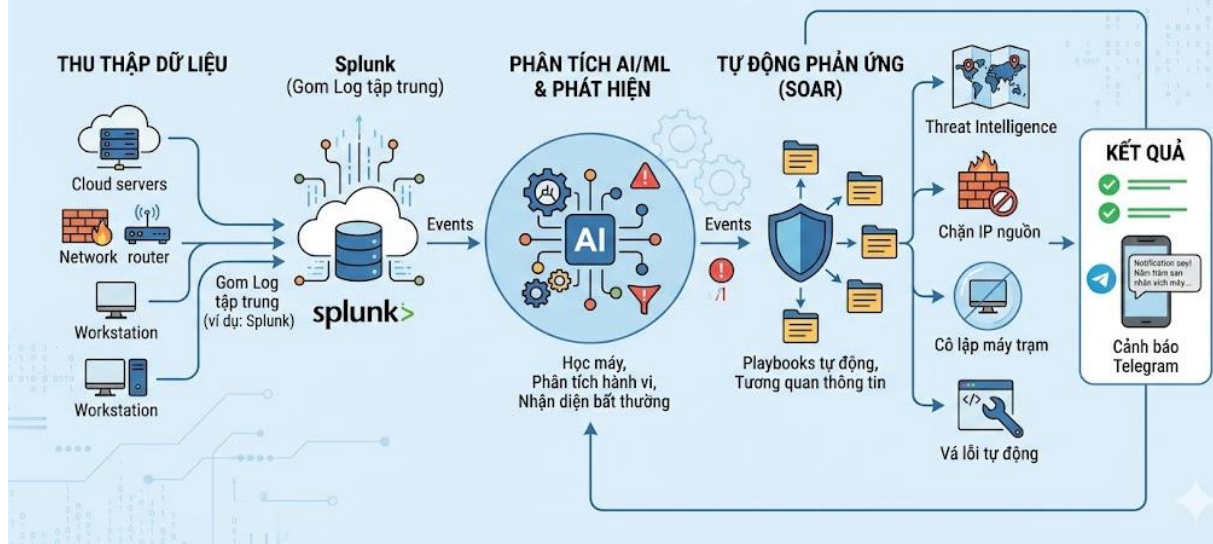
Automating security incident analysis and response with Intelligent SOC

Sơ đồ mạng Công ty Shangri-la E-Commerce



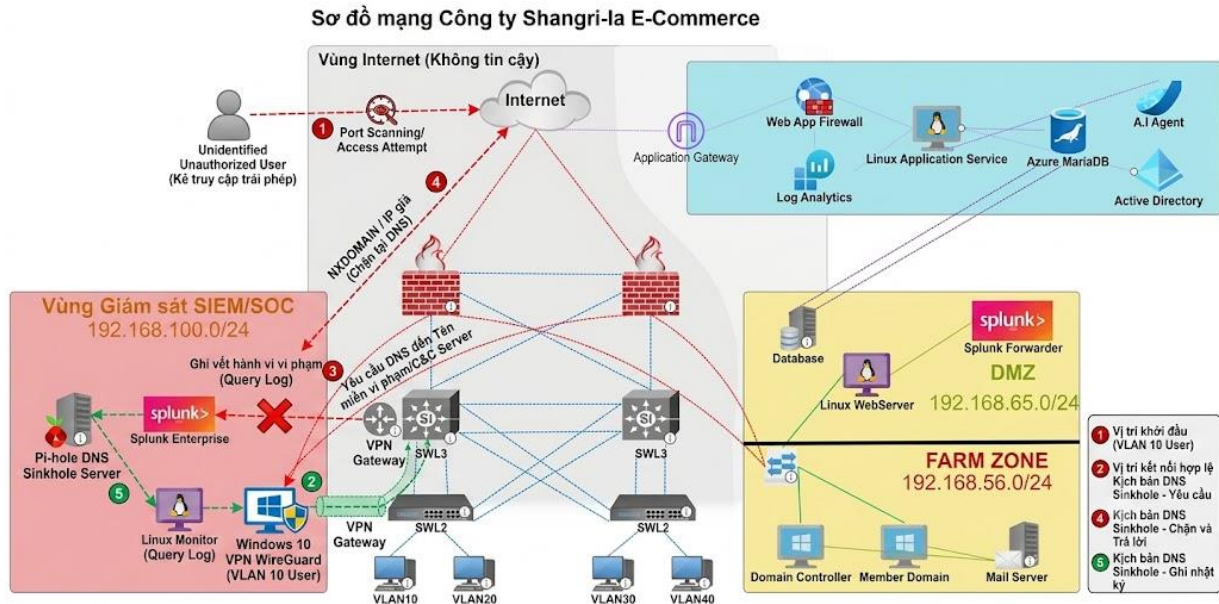
HỆ THỐNG SOC THÔNG MINH: TỰ ĐỘNG PHÂN TÍCH VÀ PHẢN ỨNG SỰ CỐ BẢO MẬT

Tự động hóa phân tích và phản ứng sự cố bảo mật với Intelligent SOC



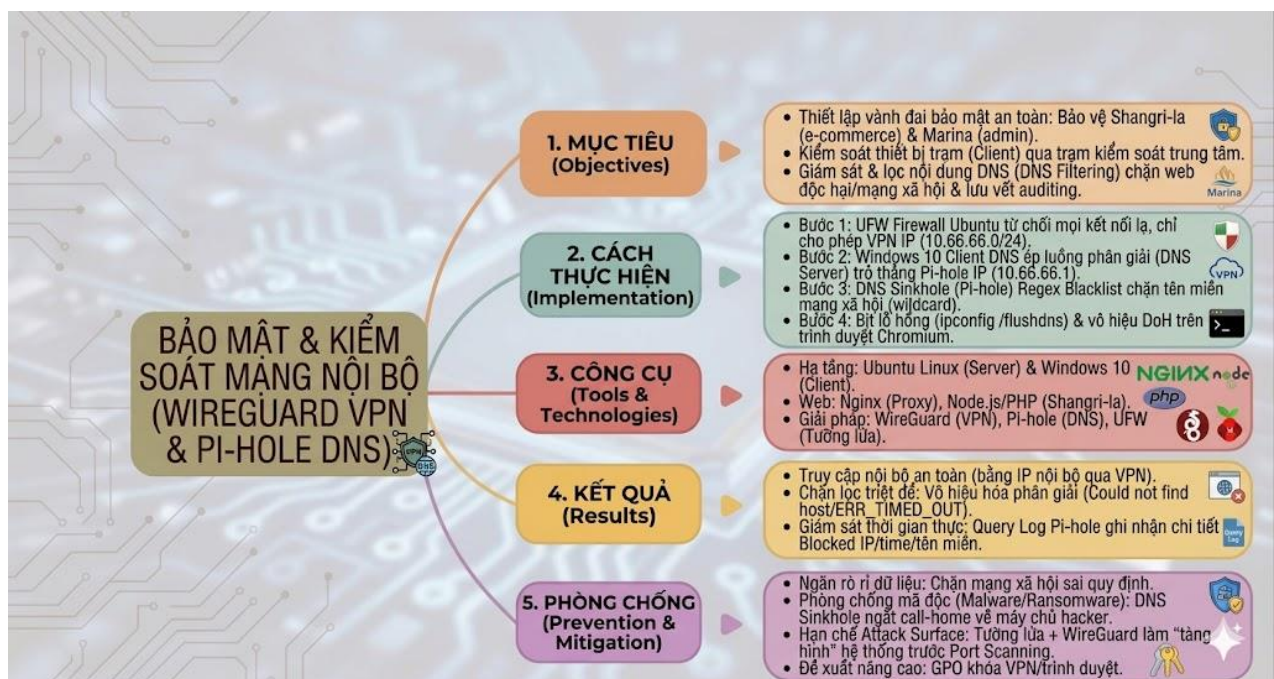
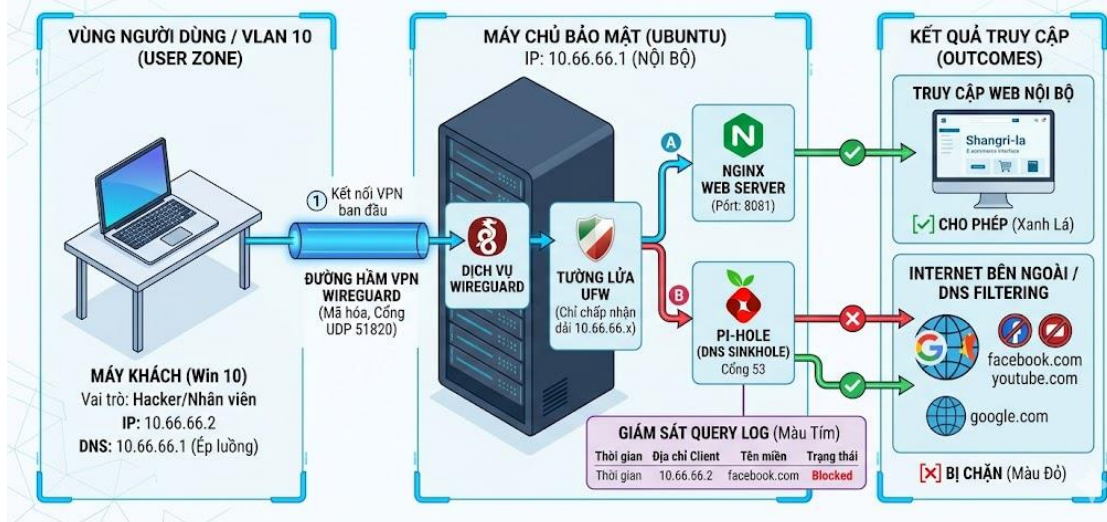
3.12 Tích hợp Wireguard VPN và Giám sát DNS Sinkhole để Quản lý truy cập

Integrating Wireguard VPN and DNS Sinkhole Monitoring for Access Management



TÍCH HỢP WIREGUARD VPN & GIÁM SÁT DNS SINKHOLE

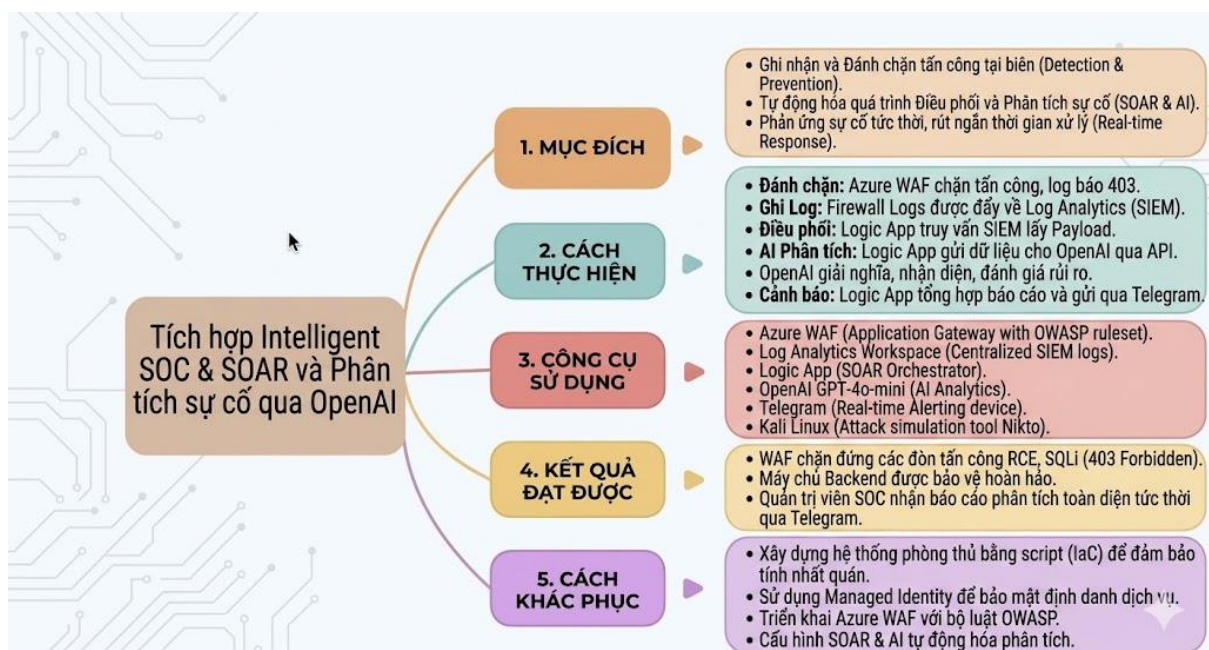
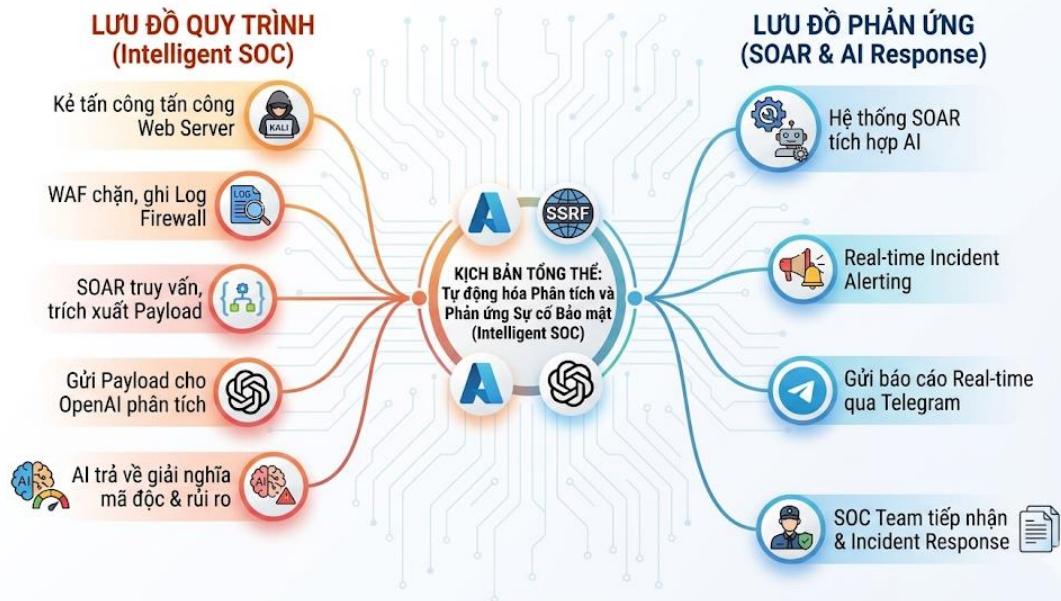
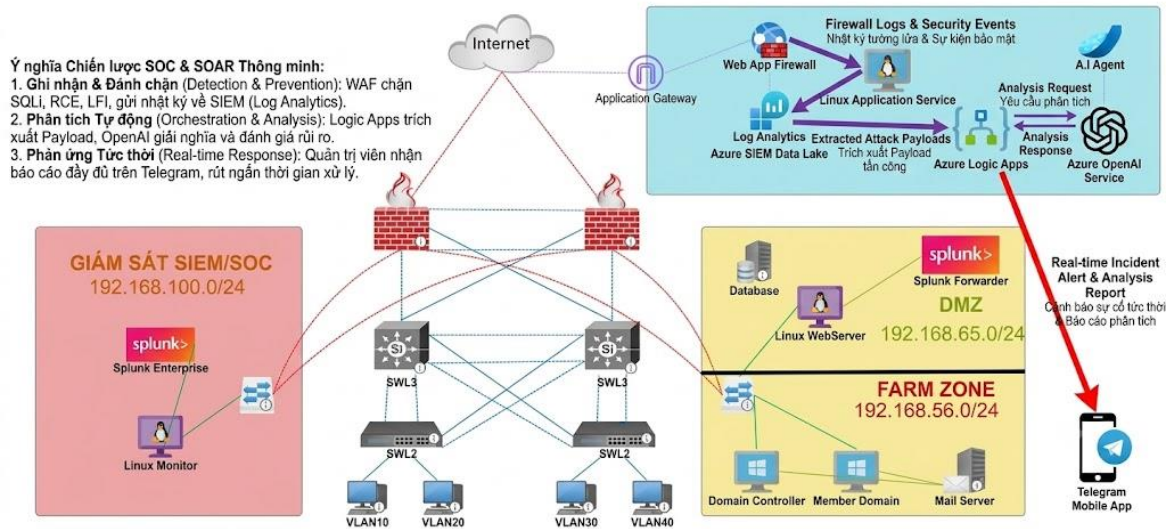
QUẢN LÝ TRUY CẬP & BẢO MẬT HỆ THỐNG MERN STACK



3.13 Tích hợp Intelligent SOC trên Azure và Phân tích sự cố qua OpenAI

Integrating Intelligent SOC and Incident Analysis via OpenAI

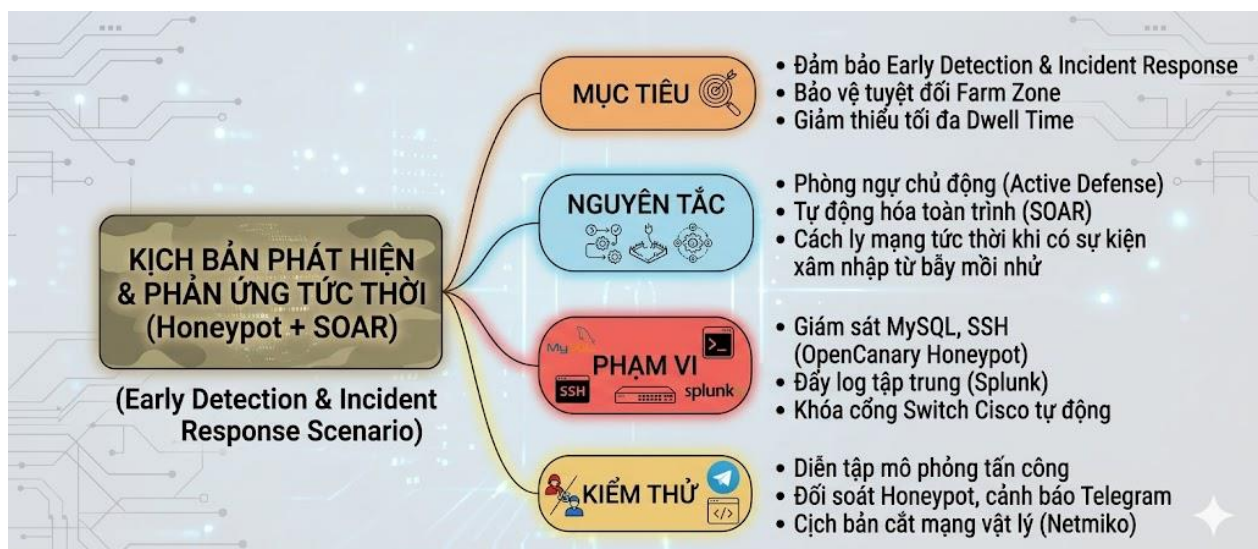
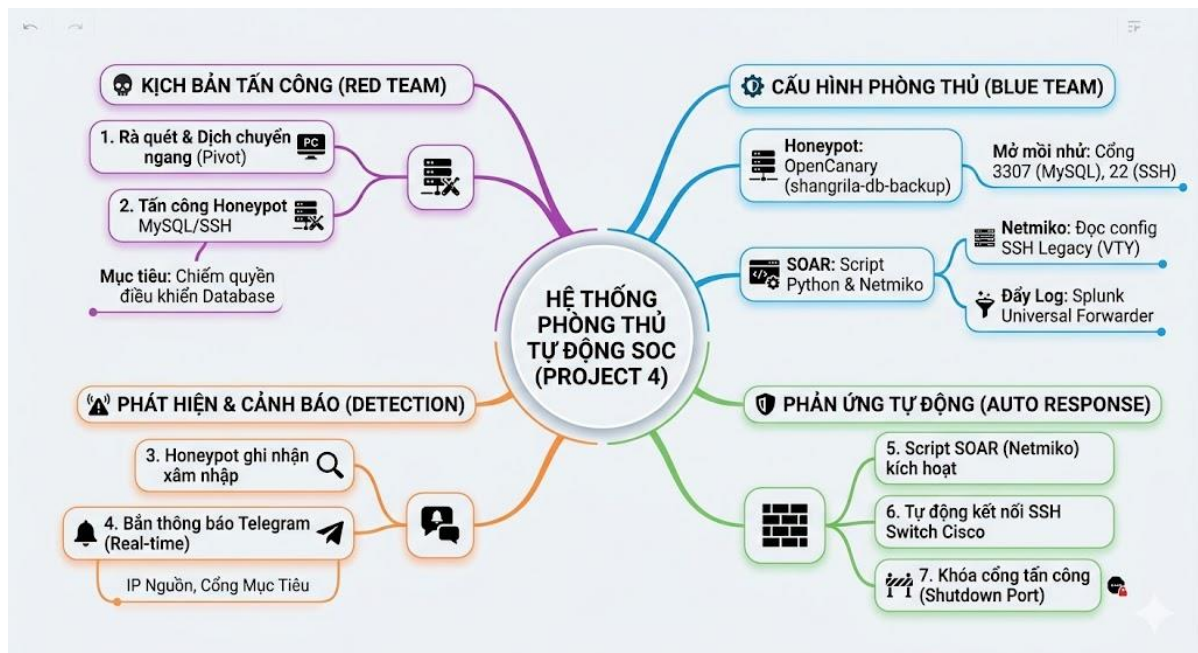
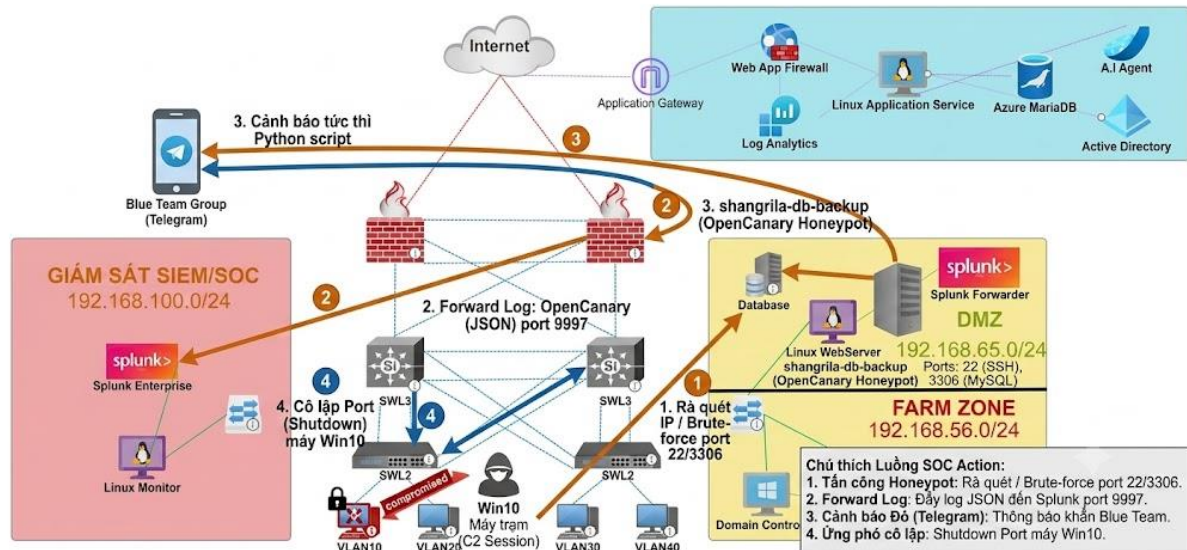
Sơ đồ mạng Nâng cao: Chiến lược Intelligent SOC & SOAR cho Công ty Shangri-la E-Commerce



3.14 Tạo bẫy Honeypot tích hợp Netmiko tự động khoá Port tấn công

Deploy a Netmiko-integrated Honeypot automatically blocking attack ports

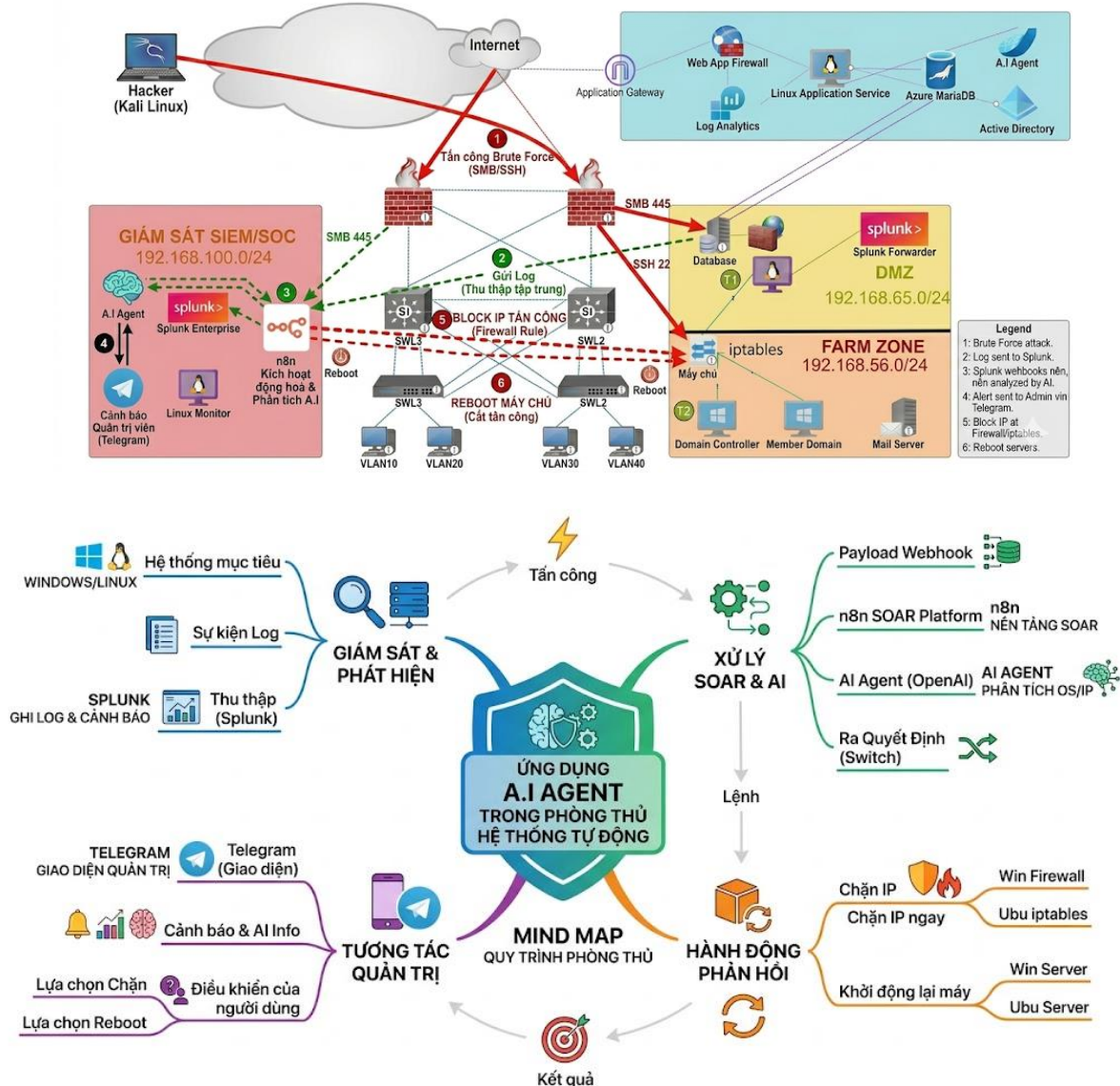
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.15 Ứng dụng A.I Agent trong tự động hóa phòng thủ hệ thống

Detect attacks, Trace malicious IPs, Alert via Telegram, and Auto-block hackers in real time

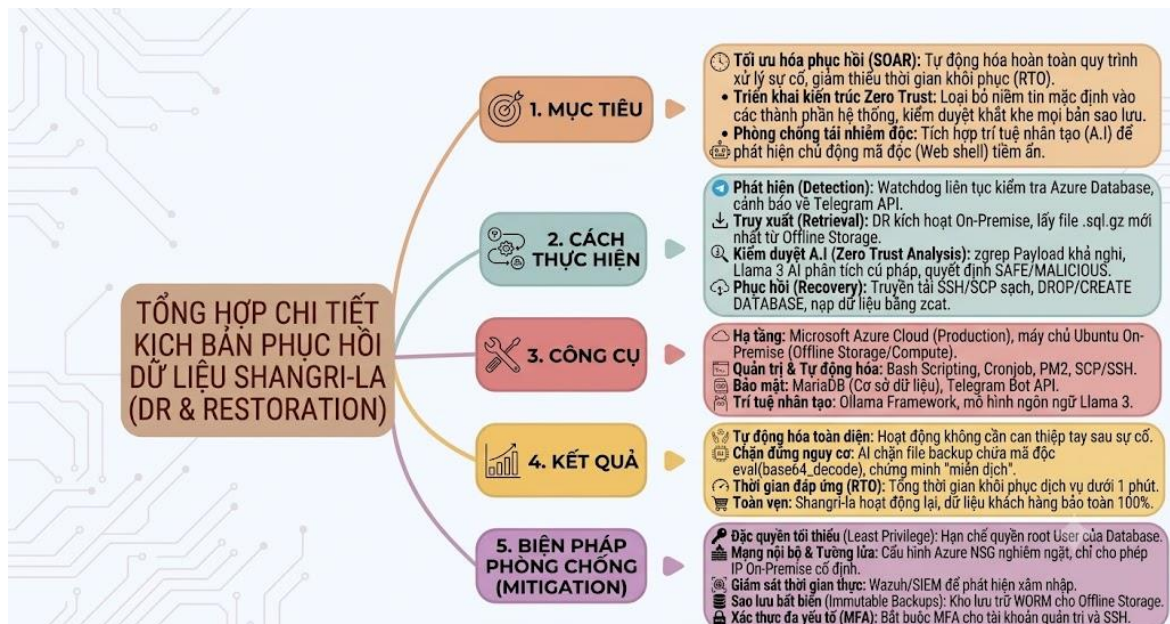
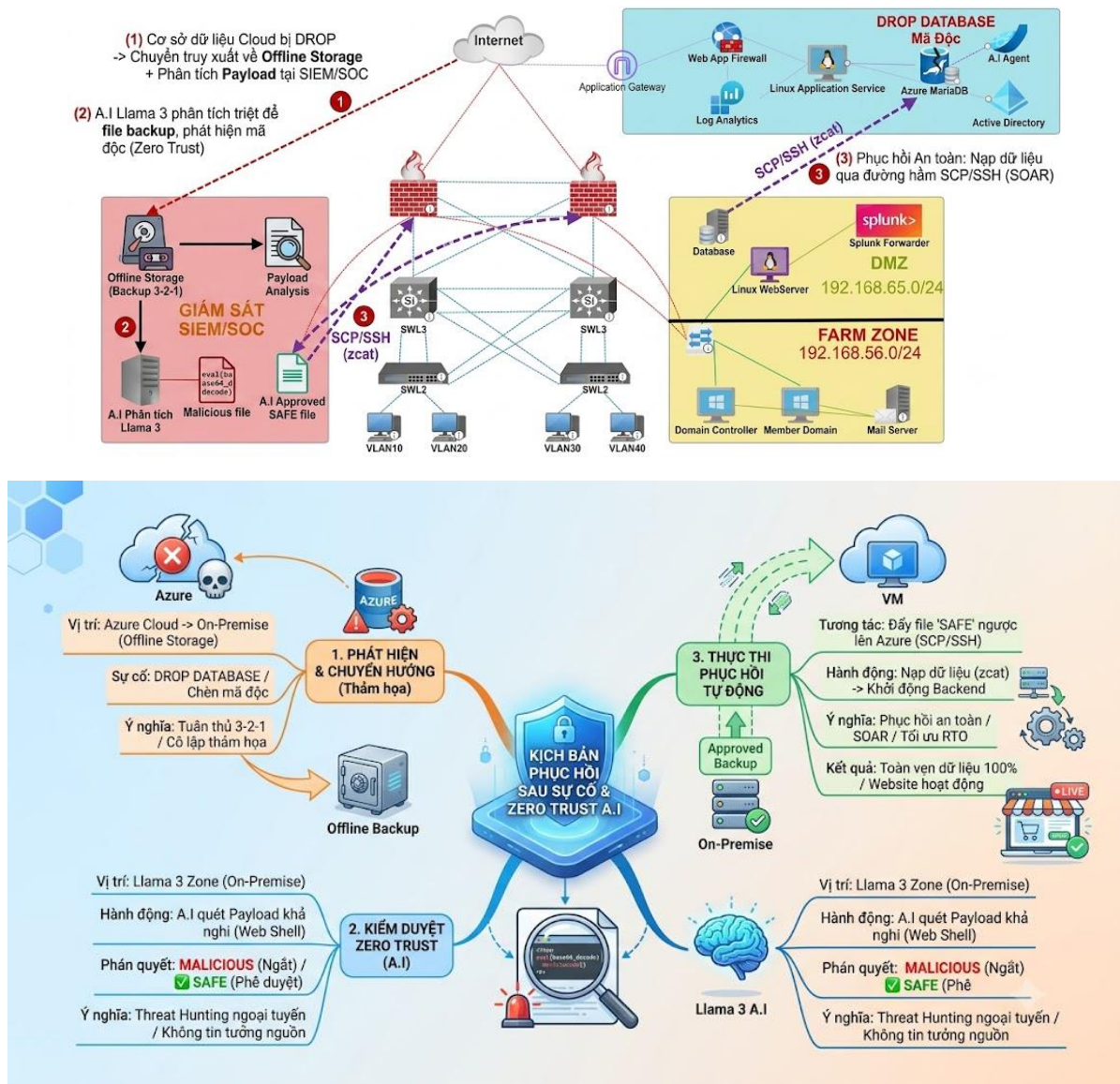
Sơ đồ mạng Công ty Shangri-la E-Commerce



3.16 Phục hồi sau sự cố & Tích hợp cơ chế Zero Trust cùng Llama 3 A.I

Disaster Recovery & Zero Trust Mechanism Integration with Llama 3 A.I.

Sơ đồ mạng Công ty Shangri-la E-Commerce



CHƯƠNG 4: ĐỀ XUẤT GIẢI PHÁP

4.1 Xác thực đa yếu tố & Khóa tài khoản (Brute-force AD)

- **Cấu hình Group Policy Object (GPO):** Thiết lập Account Lockout Threshold trên Windows Server 2022 để khóa tài khoản (ví dụ: sau 5 lần nhập sai) và quy định thời gian khóa qua Account Lockout Duration nhằm chặn đứng các cuộc tấn công Brute-force ồ ạt.
- **Triển khai MFA:** Bắt buộc áp dụng Xác thực đa yếu tố cho các tài khoản đặc quyền (Admin/Service Account).
- **Giám sát chống dò rỉ rả (Low and Slow):** Để khắc phục hạn chế của GPO (tin tặc có thể dò dưới 5 lần/ngày để né luật khóa), hệ thống sử dụng Splunk truy vấn tương quan Event ID 4625 (Logon Failure) và 4740 (Account Locked). Cấu hình Splunk đếm tổng số lần đăng nhập sai trải dài qua nhiều giờ hoặc từ nhiều IP, đảm bảo phát hiện mọi nỗ lực dò mật khẩu tinh vi.

4.2 Firewall & WAF bảo vệ Cloud (Footprinting/Scanning/SSRF)

- **Kiểm soát bề mặt mạng (Firewall):** Cấu hình Fortinet và Azure NSG với nguyên tắc "Deny All" mặc định. Chỉ cho phép mở cổng 80/443 ra Internet; các cổng quản trị như 3389/22 bị chặn hoàn toàn và chỉ cho phép truy cập từ dải IP VPN nội bộ.
- **Ngăn chặn SSRF từ gốc (IMDSv2):** Kích hoạt Azure WAF ở chế độ Prevention Mode, cấu hình Custom Rules chặn các truy vấn hướng tới dải IP Metadata của Azure (169.254.169.254). Quan trọng hơn, hệ thống vô hiệu hóa IMDSv1 (dễ bị khai thác qua HTTP GET đơn giản) và chuyển sang IMDSv2. Giao thức này yêu cầu phương thức HTTP PUT kèm Header đặc biệt (`Metadata: true`), khiến tin tặc gần như không thể giả mạo yêu cầu đánh cắp Token thông qua lỗ hổng SSRF trên Web.

4.3 Phòng chống SQL Injection & Sqlmap

- **Phòng thủ vòng ngoài (Web Application Firewall):** Triển khai Azure WAF kết hợp bộ luật OWASP Core Rule Set (CRS) để tự động nhận diện và chặn các dấu hiệu tấn công đặc trưng của công cụ Sqlmap (như UNION SELECT, SLEEP()) hoặc User-Agent bất thường).
- **Giải quyết cốt lõi tại Backend (Prepared Statements):** Do WAF có nguy cơ bị vượt qua (Bypass) bằng các kỹ thuật mã hóa (URL/Hex Encoding), hệ thống áp dụng Prepared Statements (Tham số hóa câu lệnh) trong thư viện mysql2 của Node.js. Kỹ thuật này tách biệt hoàn toàn "cấu trúc lệnh SQL" khỏi "dữ liệu đầu vào", khiến mọi payload độc hại bị ép hiểu như một chuỗi văn bản vô hại.

4.4 Giám sát tập trung & Cảnh báo (Splunk)

- **Gom log thời gian thực:** Cài đặt Splunk Universal Forwarder trên toàn bộ máy chủ Web và AD để đẩy log về máy chủ giám sát trung tâm.
- **Tự động hóa SOAR có kiểm soát (Human-in-the-loop):** Splunk được thiết lập Alert Action kích hoạt script Python gọi Telegram API để cảnh báo. Để tránh rủi ro hệ thống tự động nhận diện nhầm (False Positive) và cắt mạng máy chủ quan trọng, giải pháp SOAR (n8n) được tích hợp danh sách trắng (White-list) cho MAC/IP quản trị. Mọi hành động cô lập vật lý qua Netmiko đều được đẩy về Telegram để Blue Team xác nhận trước khi thực thi.

4.5 Ngăn chặn nghe lén (MITM)

- **Bảo vệ toàn vẹn truyền tải (Layer 7):** Cấu hình tiêu chuẩn SSL/TLS (HTTPS) cho toàn bộ Website Shangri-la và Database nội bộ để mã hóa dữ liệu, chống đọc lén cleartext.
- **Chống giả mạo gói tin (Layer 2):** Kích hoạt Dynamic ARP Inspection (DAI) và DHCP Snooping trên thiết bị Switch Cisco. Cơ chế DAI sẽ đối chiếu mọi gói tin ARP với cơ sở dữ liệu cấp phát (DHCP Snooping Binding Database). Khi Ettercap tung gói tin giả mạo chứa cặp MAC-IP sai lệch với dữ liệu ban đầu, Switch lập tức tự động loại bỏ (Drop), chặn đứng hoàn toàn kỹ thuật ARP Spoofing.

4.6 Kiểm soát kết nối & Toàn vẹn dữ liệu (Reverse Shell/Data Integrity)

- **Lọc luồng đi (Egress Filtering) & DPI:** Cấu hình Firewall áp dụng Egress Filtering để chặn các cổng kết nối ngược phổ biến (ví dụ: cổng 4444), chỉ mở các luồng ra hợp lệ (ví dụ: cổng 443 để update). Nếu tin tặc cố tình thiết lập Reverse Shell qua cổng 443 để ngụy trang, tính năng Deep Packet Inspection (DPI) trên NGFW sẽ phân tích cấu trúc gói tin (nhận diện đặc tính Command Line thay vì Web) để cắt đứt kết nối.
- **Input Validation:** Backend kiểm tra và làm sạch chặt chẽ mọi dữ liệu người dùng nhập vào, ngăn chặn hành vi sử dụng Burp Suite để can thiệp, thay đổi giá trị đơn hàng hoặc giá sản phẩm.

4.0 Bảo vệ tài khoản dịch vụ (Kerberoasting)

- **Nâng cấp độ phức tạp và mã hóa:** Yêu cầu mật khẩu siêu mạnh (> 25 ký tự) cho các tài khoản SPN (Service Principal Name). Đồng thời, hệ thống vô hiệu hóa chuẩn mã hóa RC4 lỗi thời, chuyển sang mã hóa Kerberos AES-256, khiến thời gian bẻ khóa ngoại tuyến (Offline Cracking) bằng Hashcat tốn tài nguyên và thời gian không tương.
- **Giám sát yêu cầu nội tuyến:** Tuy không thể ngăn tin tặc crack mã băm tại máy cá nhân, hệ thống theo dõi sát sao bước gom mã băm nội tuyến bằng cách dùng Splunk truy vết Event ID 4769. Việc xuất hiện lượng lớn TGS Request bất thường trong thời gian ngắn sẽ ngay lập tức kích hoạt cô lập hệ thống.

4.1 Giới hạn tốc độ truy cập (DDoS Slowloris)

- **Cấu hình Nginx chống cạn kiệt tài nguyên:** Khác với DDoS tràn băng thông, Slowloris duy trì hàng ngàn kết nối ảo để làm cạn kiệt Pool Connection. Server Nginx được cấu hình module `limit_conn` và `limit_req` để giới hạn số kết nối từ một IP. Các thông số Timeout được tinh chỉnh cực ngắn nhằm chủ động ngắt (Drop) các phiên kết nối cố tình câu giờ.
- **Giảm tải ứng dụng Layer 7:** Kết hợp Azure Front Door để tự động nhận diện, hấp thụ lưu lượng và ngắt các luồng kết nối không hoàn thành hoặc kéo dài bất thường từ Internet.

4.2 Email Security & Least Privilege

- **Bộ ba xác thực Email chống Phishing:** Triển khai đồng thời cơ chế SPF (kiểm tra IP nguồn), DKIM (ký điện tử chống thay đổi nội dung) và DMARC (chính sách cách ly/từ chối khi trượt xác thực) cho Mail Server. Sự kết hợp này triệt tiêu hoàn toàn các kỹ thuật giả mạo tên miền Shangri-la gửi email lừa đảo cho nhân viên.
- **Nguyên tắc Đặc quyền tối thiểu (RBAC):** Áp dụng Role-Based Access Control khắt khe. Các tài khoản (như kế toán) chỉ được cấp quyền xem đơn hàng, tuyệt đối không có quyền xóa sản phẩm hoặc thao tác trực tiếp với Database, thu hẹp tối đa bán kính thiệt hại (Blast Radius) nếu một tài khoản bị lộ.

4.3 Phục hồi dữ liệu sạch (Recovery)

- **Quy tắc sao lưu 3-2-1:** Duy trì 1 bản backup trên Cloud Azure, 1 bản tại máy chủ Backup nội bộ và 1 bản lưu trữ ngoại tuyến (Offline) ngắt hoàn toàn kết nối mạng.
- **Quy trình Air-Gapped Sandboxing:** Khi xảy ra sự cố, toàn bộ dữ liệu dự phòng phải được bung ra môi trường cách ly (Phòng sạch - Sandbox). Phân vùng này cô lập vật lý và logic, không có định tuyến (Routing) ngược về mạng vận hành (Production). Tại đây, quy trình quét mã độc nằm vùng bằng công cụ Forensic được thực hiện ngoại tuyến, đảm bảo dữ liệu "Sạch" 100% trước khi cấp phép khôi phục dịch vụ.

CHƯƠNG 5: ĐIỀU TRA SỐ

Quá trình điều tra số tại Shangri-la đóng vai trò then chốt trong việc truy vết sự cố, đánh giá thiệt hại và cung cấp bằng chứng kỹ thuật sau các đợt kiểm thử xâm nhập (Pentest) hoặc khi đối mặt với các rủi ro thực tế.

5.0 Quy trình và Nguyên tắc Điều tra số

Để đảm bảo tính toàn vẹn và giá trị pháp lý của các bằng chứng thu thập được trên cả hạ tầng On-premise và Azure Cloud, đội ngũ Blue Team tuân thủ quy trình 4 bước chuẩn:

1. **Thu thập:** Trích xuất Dữ liệu thô (RAM dump, Disk image, PCAP, Azure Logs) với mức độ xâm lấn tối thiểu. Ưu tiên thu thập theo thứ tự dữ liệu dễ bay hơi (Order of Volatility).
2. **Khảo sát:** Trích xuất và lập chỉ mục dữ liệu thô thành các định dạng có thể phân tích.
3. **Phân tích:** Ghép nối các sự kiện, dựng lại Timeline tấn công để tìm ra nguyên nhân gốc rễ dựa trên các kịch bản đã bị Red Team khai thác.
4. **Báo cáo:** Lập biên bản điều tra (Incident Report) đính kèm bằng chứng (Evidence) rõ ràng.

5.1 Bộ công cụ Điều tra chuyên dụng (Forensic Toolset)

Hệ thống phòng thủ của Shangri-la sử dụng sự kết hợp giữa các công cụ mã nguồn mở và nền tảng giám sát doanh nghiệp:

- Công cụ Thu thập:
- **FTK Imager:** Dùng để chụp lại toàn bộ bộ nhớ RAM (Memory Dump) hoặc tạo bản sao ổ cứng (Disk Image) của máy chủ Windows Server 2022 / Ubuntu Linux ngay khi phát hiện sự cố mà không làm thay đổi hiện trường.
- **Phân tích Bộ nhớ & Ổ đĩa (Memory & OS Forensics):**
 - **Volatility:** "Vũ khí hạng nặng" phân tích file memory dump từ FTK Imager để tìm các tiến trình (process) độc hại chạy ngầm (Fileless malware) hoặc các kết nối Reverse Shell bị giấu đi.
 - **Autopsy:** Phân tích Disk Image, khôi phục các tệp tin mã độc (như shell.php) mà hacker đã xóa để phi tang bằng chứng, rà soát lịch sử thay đổi file hệ thống.
- **Phân tích Log & Sự kiện (Log Analysis):**
 - **Splunk Enterprise & Sysmon:** Sysmon ghi lại chi tiết từng lệnh command line, ID tiến trình và đẩy về Splunk. Rất hữu ích để điều tra các vụ Kerberoasting hoặc Brute-force trên Domain Controller.
 - **Azure Monitor & Log Analytics (KQL):** Sử dụng Kusto Query Language để săn tìm dấu vết tấn công trên môi trường Cloud (SSRF, dò IP bất thường).
- **Phân tích Mạng (Network Forensics):**
 - **Wireshark:** Trích xuất và phân tích các file PCAP để tìm gói tin HTTP chứa thông tin đăng nhập bị đọc lén (khi bị MITM/ARP Spoofing).
 - **Brim Security / Zeek:** Xử lý các file PCAP dung lượng lớn, lọc nhanh các luồng traffic độc hại.
- **Phân tích Payload & Tệp tin:**
 - **ExifTool & Binwalk:** Kiểm tra metadata và trích xuất các mã độc bị nhúng ẩn (Steganography) bên trong tệp tin hình ảnh tải lên website.

5.2 Thực thi Điều tra số theo Kịch bản tấn công (Forensic Scenarios)

Dựa trên các kịch bản kiểm thử của hệ thống Shangri-la, quá trình điều tra số được phân chia thành 4 mảng chính:

5.2.1 Web & Database Forensics (Ứng dụng Node.js/React & MariaDB)

- **Tình huống:** Website bị khai thác lỗ hổng SQL Injection (tự động bằng Sqlmap), Upload mã độc, hoặc thiết lập Reverse Shell.
- **Hành động điều tra:**
 - **Phân tích Log (Splunk & Azure WAF):** Rà soát log Nginx và WAF để tìm các payload đặc trưng như UNION SELECT, OR '1'='1 hoặc các tham số --dump từ Sqlmap.
 - **Phân tích Payload (ExifTool/Binwalk):** Thu thập các file ảnh/tài liệu đáng ngờ trên thư mục upload của Web Server. Phân tích để tìm mã thực thi PHP/Node.js bị chèn giấu.
 - **Phân tích RAM (Volatility):** Nếu phát hiện dấu hiệu chiếm quyền, dump RAM của Web Server để tìm các kết nối outbound đáng ngờ (cổng 4444) trở về IP của máy Kali Linux (Attacker).
 - **Khôi phục hiện trường (Autopsy):** Trích xuất Disk Image của Web Server để quét thư mục webroot, tìm lại các web shell đã bị hacker tự động xóa.

5.2.2 Identity & OS Forensics (Máy chủ Domain Controller - Windows Server 2022)

- **Tình huống:** Máy chủ quản lý miền bị Brute-force qua SMB hoặc tấn công Kerberoasting lấy cắp mật khẩu Service Account.
- **Hành động điều tra:**
 - **Truy vết Event Logs:** Sử dụng Splunk truy vấn các Windows Event ID như 4625 (Đăng nhập thất bại nhiều lần - Brute force) và 4769 (Yêu cầu vé dịch vụ TGS bất thường - Kerberoasting).
 - **Phân tích Sysmon:** Đào sâu vào log Sysmon trên máy chủ DC để xem hacker có thực thi các lệnh powershell, sử dụng công cụ Impacket hay cố gắng leo thang đặc quyền (Privilege Escalation) hay không.
 - **Bảo lưu bằng chứng:** Trích xuất các log xung đột xác thực và danh sách tài khoản bị khóa làm biên bản báo cáo rủi ro cho phòng IT.

5.2.3 Cloud Forensics (Microsoft Azure & Hybrid Cloud)

- **Tình huống:** Bị khai thác SSRF để truy xuất Metadata trái phép hoặc bị tấn công từ chối dịch vụ (DDoS Slowloris) làm cạn kiệt tài nguyên.
- **Hành động điều tra:**
 - **Truy vấn KQL (Kusto Query Language):** Phân tích Azure Log Analytics để tìm các nỗ lực truy cập bất thường vào dải IP nội bộ dành riêng của Azure (169.254.169.254).
 - **Phân tích lưu lượng:** Xác định các địa chỉ IP mở hàng ngàn kết nối HTTP mà không hoàn thành (đặc trưng của Slowloris), trích xuất biểu đồ biến động CPU và số lượng kết nối để đánh giá mức độ thiệt hại.

5.2.4 Network & Mail Forensics (Mạng nội bộ và Email lừa đảo)

- **Tình huống:** Mạng LAN bị nghe lén (Man-in-the-Middle qua Ettercap) và nhân viên bị gửi Email Phishing.
- **Hành động điều tra:**
 - **Điều tra MITM (Wireshark/Brim):** Thu thập các bản ghi PCAP tại Switch trung tâm. Tìm kiếm các xung đột địa chỉ MAC (MAC Conflict Logs) và các bản tin ARP giả mạo. Phân tích sâu để xem liệu có dữ liệu nhạy cảm nào bị truyền dưới dạng cleartext (HTTP, Telnet) không.
 - **Điều tra Email:** Thu thập thư điện tử nghi ngờ. Phân tích Header Email để tìm nguồn gốc giả mạo (Spoofed IP/Domain) và dùng các công cụ sandbox để phân tích mã độc chứa trong attachment gửi tới nhân viên.

CHƯƠNG 6: ĐÁNH GIÁ ĐỀ TÀI

6.0 Hiệu quả kỹ thuật theo từng phân vùng

Phân vùng	Tình trạng trước khi Pentest	Kết quả sau khi triển khai giải pháp
Quản trị hệ thống (AD/DC)	Dễ bị Brute-force mật khẩu và tấn công Kerberoasting chiếm quyền Admin.	Đã bật MFA bắt buộc , chính sách khóa tài khoản tự động và nâng cấp mã hóa lên AES-256 .
Ứng dụng Web (Shangri-la)	Tồn tại lỗ hổng SQL Injection (thủ công & tự động), SSRF trên Azure, và lỗi phân quyền IDOR.	Triển khai WAF chặn payload độc hại, áp dụng Prepared Statements và kiểm tra quyền tại Backend (RBAC).
Hạ tầng mạng nội bộ	Dễ bị nghe lén dữ liệu (MITM) qua ARP Spoofing và bị chiếm quyền qua Reverse Shell.	Bật Dynamic ARP Inspection (DAI) , mã hóa toàn bộ bằng HTTPS/TLS và cấu hình Egress Filtering chặn kết nối lạ ra ngoài.
Hạ tầng Cloud (Azure)	Thiếu giám sát nhật ký truy cập, dễ bị tấn công DDoS tầng ứng dụng.	Sử dụng KQL (Kusto Query Language) để săn tìm dấu vết tấn công và cấu hình Rate Limiting chặn đứng DDoS Slowloris.

6.1 Năng lực giám sát và Phản ứng sự cố (SOC)

Thay vì kiểm tra log thủ công, hệ thống hiện tại đã đạt được khả năng tự động hóa cao:

- **Giám sát tập trung:** Sử dụng **Splunk** để theo dõi mọi hành vi đáng ngờ. Hệ thống sẽ tự động gửi cảnh báo qua **Telegram** nếu phát hiện một IP đăng nhập sai quá 20 lần.
- **Xử lý mã độc:** Triển khai cơ chế **No-Execute** tại các thư mục tải lên và tự động đổi tên tệp tin để ngăn chặn thực thi script độc hại (Shell.php).
- **Phòng chống Phishing:** Thiết lập bộ lọc cho Mail Server kết hợp đào tạo nhận thức giúp giảm thiểu nguy cơ lộ lọt tài khoản qua Email.

6.2 Bảo toàn dữ liệu và Phục hồi sau sự cố

Hệ thống sao lưu đã được chuẩn hóa để đảm bảo tính sẵn sàng cao nhất cho doanh nghiệp:

- **Quy tắc 3-2-1:** Áp dụng nghiêm ngặt việc lưu trữ 3 bản sao trên 2 loại phương tiện khác nhau và 1 bản Offsite (Cloud Azure).
- **Cam kết chỉ số:** Đã thực hiện kiểm thử phục hồi định kỳ, đảm bảo đạt mục tiêu **RTO** (Thời gian phục hồi) và **RPO** (Điểm phục hồi) theo yêu cầu kinh doanh.

6.3 Đánh giá tổng quát

6.3.1 Tổng quan

- Đề tài đã hoàn thành đúng mục tiêu nghiên cứu và triển khai bảo mật cho hệ thống thương mại điện tử **Shangri-la** trong môi trường Hybrid Cloud. Nhóm đã không chỉ dừng lại ở việc kiểm thử các lỗ hổng web cơ bản mà còn mở rộng sang các kịch bản tấn công hạ tầng Active Directory (AD) và khai thác dịch vụ đám mây Azure.

6.3.2 Kết quả đạt được

- **Mô phỏng kịch bản tấn công thực tế:** Nhóm đã thực hiện thành công các kỹ thuật từ mức độ thâm nhập ban đầu (Footprinting/Scanning với AI) đến khai thác chuyên sâu (SQL Injection, SSRF, Kerberoasting) và chiếm quyền điều khiển (Reverse Shell).
- **Bảo mật website Shangri-la toàn diện:** Khắc phục triệt để các lỗi thuộc OWASP Top 10 như Broken Access Control (IDOR), SQL Injection và Data Integrity Failure (Upload mã độc) thông qua giải pháp WAF và chuẩn hóa mã nguồn.
- **Nâng cao năng lực giám sát (Blue Team):** Ứng dụng **Splunk** và **Azure Monitor (KQL)** để thiết lập hệ thống cảnh báo tự động khi phát hiện dấu vết tấn công Brute-force hoặc quét mạng trái phép.
- **Chuẩn hóa quy trình dự phòng:** Thiết lập chiến lược sao lưu dữ liệu theo quy tắc 3-2-1, đảm bảo các chỉ số RTO/RPO cho database và file server của hệ thống Shangri-la.

6.3.3 Kiến thức và Kỹ năng tiếp thu

- **Kiến thức chuyên sâu:** Hiểu rõ cơ chế hoạt động của các giao thức bảo mật hiện đại (TLS/SSL, Kerberos AES-256) và cách thức vận hành của một trung tâm điều hành an ninh (SOC).
- **Công cụ:** Thành thạo các bộ công cụ "hạng nặng" trong ngành như **Burp Suite, Metasploit, Sqlmap, Hydra, Ettercap** và các ngôn ngữ truy vấn chuyên dụng như **KQL**.
- **Tư duy phản biện:** Khả năng phân tích dấu vết kỹ thuật số (Forensics) từ nhật ký hệ thống (Event Logs) để truy tìm nguồn gốc cuộc tấn công.

6.3.4 Ưu điểm

- **Tính thực tiễn cao:** Các kịch bản tấn công được xây dựng dựa trên những nguy cơ thực tế nhất hiện nay như lừa đảo qua Email (Phishing) hay khai thác lỗi logic trong phân quyền người dùng.
- **Tích hợp công nghệ tiên tiến:** Việc đưa **trí tuệ nhân tạo (AI)** vào giai đoạn thu thập thông tin và quét lỗ hổng giúp tăng tốc độ triển khai dự án đáng kể.
- **Bằng chứng thuyết phục:** Mỗi kịch bản đều có sự đối chiếu rõ ràng giữa hành động tấn công của Hacker và phản ứng phòng thủ của quản trị viên hệ thống.

6.3.5 Nhược điểm

- **Rào cản về tài chính:** Một số giải pháp như SIEM Splunk hay hệ thống Azure WAF chuyên dụng đòi hỏi kinh phí duy trì lớn, có thể gây khó khăn cho các doanh nghiệp quy mô nhỏ.
- **Độ phức tạp kỹ thuật:** Việc vận hành và viết các luật truy vấn KQL/Splunk đòi hỏi đội ngũ nhân sự phải được đào tạo bài bản và liên tục cập nhật kiến thức.

CHƯƠNG 7: ĐỊNH HƯỚNG PHÁT TRIỂN

7.1. Nâng cấp Hệ thống Giám sát và Phản ứng (Từ SIEM lên SOAR & XDR)

Hệ thống giám sát hiện tại đã cấu hình tốt việc thu thập log tập trung và cảnh báo chủ động, nhưng vẫn cần sự can thiệp thủ công của con người khi có sự cố. Định hướng tiếp theo sẽ tập trung vào tự động hóa và mở rộng kiến trúc giám sát:

- **Tự động hóa phản ứng bằng SOAR (Security Orchestration, Automation, and Response):** Nâng cấp các script Python và hệ thống Splunk hiện tại lên mô hình SOAR. Khi phát hiện hành vi tấn công (ví dụ: SQL Injection hoặc Brute-force), hệ thống sẽ tự động kích hoạt các kịch bản phản ứng (Playbooks) như: tự động cấu hình Firewall để chặn IP của kẻ tấn công, cô lập tài khoản bị nghi ngờ mà không cần chờ quản trị viên phê duyệt thủ công.
- **Tích hợp giải pháp giám sát xâm nhập máy chủ (HIDS/XDR):** Bên cạnh việc thu thập log từ thiết bị ngoại vi như Firewall và Nginx, hệ thống sẽ tích hợp thêm các giải pháp phát hiện xâm nhập chuyên dụng trên host (HIDS). Giải pháp này sẽ giám sát sâu vào tính toàn vẹn của file cấu hình, kiểm tra Registry trên Windows Server 2022 và các tiến trình chạy ngầm trên Linux Web Server, tạo nên một hệ sinh thái SOC (Security Operations Center) toàn diện từ tầng mạng đến tầng lõi máy chủ.

7.2. Hiện thực hóa Kiến trúc An ninh Không tin cậy (Zero Trust Architecture)

Hạ tầng hiện tại vẫn đang phụ thuộc nhiều vào ranh giới mạng truyền thống (bảo vệ bằng VLAN và chính sách cấu hình Port trên Firewall). Để tối ưu bảo mật, hệ thống cần chuyển sang mô hình Zero Trust với nguyên tắc cốt lõi: *"Không bao giờ tin tưởng, luôn luôn xác minh"*.

- **Kiểm soát điểm cuối toàn diện (EDR - Endpoint Detection and Response):** Máy trạm của nhân viên là điểm đầu vào ưa thích và dễ bị khai thác nhất của tin tặc. Định hướng sẽ triển khai các giải pháp EDR trực tiếp trên từng máy trạm nhằm giám sát chặt chẽ vòng đời và hành vi của các tiến trình (process execution), ngăn chặn mã độc thực thi ngay tại thiết bị của người dùng trước khi chúng kịp lan rộng vào mạng nội bộ.
- **Áp dụng Xác thực đa yếu tố (MFA) và Quản lý đặc quyền (PAM):** Bắt buộc triển khai cấu hình MFA cho toàn bộ tài khoản trên Active Directory và các tài khoản quản trị viên tối cao trên nền tảng đám mây Azure. Giải pháp này kết hợp với việc siết chặt quyền truy cập đặc quyền sẽ bẻ gãy hoàn toàn các kịch bản tấn công chiếm quyền tinh vi như Kerberoasting hay dò quét mật khẩu diện rộng (Brute-force).

7.3. Tích hợp Bảo mật vào Vòng đời Phát triển Phần mềm (DevSecOps)

Ứng dụng Web Shangri-la (phát triển trên nền tảng Node.js/React và MariaDB) cần được bảo vệ ngay từ những dòng mã đầu tiên thay vì chỉ dựa vào việc kiểm thử, rà quét lỗ hổng bằng Burp Suite hay SQLmap sau khi sản phẩm đã hoàn thiện (giai đoạn muộn).

- **Kiểm thử an ninh tĩnh (SAST - Static Application Security Testing):** Tích hợp các công cụ tự động quét và phân tích mã nguồn nguồn tĩnh trực tiếp vào quy trình CI/CD. Công cụ sẽ phát hiện sớm các lỗi lập trình nguy hiểm trong code React và Node.js (như thiếu kiểm tra dữ liệu đầu vào, dùng thư viện lỗi thời) ngay khi lập trình viên vừa đẩy mã nguồn lên hệ thống quản lý phiên bản.
- **Kiểm thử an ninh động (DAST - Dynamic Application Security Testing):** Cấu hình tự động rà quét và giả lập tấn công vào ứng dụng đang chạy trong môi trường thử nghiệm (Staging) trước khi cho phép đóng gói và triển khai chính thức lên dịch vụ Azure Application Service, đảm bảo không có lỗ hổng nghiêm trọng nào bị lọt ra môi trường thực tế.

7.4. Ứng dụng Trí tuệ Nhân tạo và Học máy cho Blue Team

Khi các nhóm tấn công (Red Team) đã bắt đầu ứng dụng sức mạnh của AI (như sử dụng các công cụ dạng ShellGPT) để tối ưu hóa quá trình rà quét và tự động hóa các kịch bản khai thác lỗ hổng, đội phòng thủ Blue Team bắt buộc phải nâng cấp vũ khí tương xứng.

- **Phân tích hành vi người dùng và thực thể (UEBA - User and Entity Behavior Analytics):** Tích hợp các mô hình Học máy (Machine Learning) vào nền tảng giám sát log Splunk.
- **Cơ chế hoạt động thông minh:** Thay vì chỉ dựa vào các tập luật tĩnh, xơ cứng (ví dụ: chỉ cảnh báo khi phát hiện một IP nhập sai mật khẩu quá 20 lần), hệ thống AI sẽ tự học "Baseline" – tức là nhịp độ và hành vi hoạt động bình thường của từng người dùng và máy chủ trong hệ thống. Từ đó, AI có khả năng phát hiện các bất thường cực kỳ nhỏ và lén lút, chẳng hạn như hành vi âm thầm trích xuất dữ liệu ngầm (Data Exfiltration) diễn ra với tần suất thấp trong thời gian dài để kịp thời ngăn chặn.

7.5. Kế hoạch Phục hồi sau Thảm họa (Disaster Recovery & Business Continuity)

Hạ tầng hiện tại đã có các giải pháp sẵn sàng cao và chống thất nút cổ chai rất tốt (sử dụng giao thức HSRP cho hệ thống Switch nội bộ và tính năng Auto-scale tự động co giãn trên đám mây Azure). Tuy nhiên, để đảm bảo tính sống còn của doanh nghiệp, chiến lược sao lưu cần được nâng cấp toàn diện:

- **Xây dựng chính sách sao lưu định kỳ nghiêm ngặt:** Áp dụng cho các thành phần cốt lõi bao gồm Cơ sở dữ liệu MariaDB (chứa toàn bộ thông tin giao dịch, khách hàng) và máy chủ Domain Controller (quản lý định danh toàn hệ thống).
- **Triển khai Lưu trữ ngoại tuyến (Offline/Offsite Backup):** Các bản sao lưu phải được lưu trữ biệt lập hoàn toàn với mạng sản xuất hoặc lưu ở một phân vùng đám mây có tính năng bất biến (Immutable Storage). Cơ chế này đảm bảo tính toàn vẹn tuyệt đối cho dữ liệu trong kịch bản tồi tệ nhất: toàn bộ máy chủ đang hoạt động bị tấn công và mã hóa hàng loạt bởi Ransomware (mã độc tống tiền), giúp doanh nghiệp có thể nhanh chóng khôi phục hệ thống sạch và đưa hoạt động kinh doanh trở lại bình thường trong thời gian ngắn nhất.